中国电子杯

作品报告

赛题九

智能体驱动的 AI 安全知识情报系统

ShaoWang

智能体驱动的 AI 安全知识情报系统

多源实时监测、可解释关联推理与开放插件生态

提交日期：　　年　　月　　日

摘要

推理框架、模型服务与智能体平台的漏洞材料分散在通用数据库、厂商公告和研究资讯中。厂商修复信息公开时可能尚无统一编号，同一漏洞的评分与版本范围也可能存在分歧。防守方需要回答的却是具体问题：哪些漏洞影响当前依赖，依据是否充分，应该升级到哪个版本。仅汇集文章无法完成这种判断，仅生成一段回答又容易隐藏证据缺口。哨望面向 AI 基础设施设计防御侧知识情报系统，将持续发现、字段裁决、关系证据与开发工具接入放进同一流程，保留未知、候选和冲突状态，不将模型推断直接等同于事实。

作品以监测、富化、问答三条主线组织能力。监测设计覆盖 9 类来源，关键厂商公告每 5 min 轮询，无 CVE 公告以内部编号承接；第三方来源采用轮询，自有仓库与演示注入另行标记。富化按 9 个维度补全画像，先处理字段特例，再比较来源等级、置信度与修改时间，六类关联连接公告、组件、技术与处置，每条图边保留理由。问答组合 BM25、向量和图扩展，融合重排后执行显式多跳计划，答案逐句引用并经 Critic 校验；版本自查按生态求解影响区间，区分受影响、未发现已知影响和组件未收录。内部 9 个智能体以有状态图交接，PostgreSQL 为事实源；对外设计 7 个 MCP 工具，并通过 OpenAPI、命令行和插件开放，配套 8 类 Schema 与三类扩展点。PoC 只给链接，暴露面只给计数，不做主动扫描。

目前完成的工程实测包括来源连通性和 Ollama 的 Quake 查询校准。2026-10-14，主要境外来源在所测境内环境返回 HTTP 200，CNVD 与 arXiv 失败推动通道调整；首页可达未被当作业务接口完成。2026-10-15，收窄查询在 15:57 得到全球 172 411、中国 51 612，同日 19:55 的元数据抽样为 44 / 50，精确率 88%，达到 80% 门槛；两次快照分开记录，结果不外推至其他组件。性能和质量尚未完成测量：**【待测：漏洞类情报端到端时延 P95，目标值 ≤6 h】**；**【待测：200 条金标集富化准确率，目标值 ≥95%】**；**【待测：100 题评测集引用正确率，目标值 xx%】**。报告据此区分设计、参考实现、已实测与待补材料，后续将以连续观测、金标和问答对照验证效果。

关键词：AI 安全；威胁情报；多智能体；知识图谱；GraphRAG；模型上下文协议

Abstract

Intelligence about AI infrastructure is fragmented across vulnerability databases, vendor advisories and research publications. Fixes may precede common identifiers, and sources can disagree on severity and affected versions. Defenders need to identify affected dependencies, check the evidence and choose remediation. ShaoWang is a defense-oriented system designed to connect discovery, field-level resolution, traceable relationships and development tools while retaining uncertainty and separating model inferences from facts.

Monitoring covers nine source categories, polling priority vendor advisories every five minutes and retaining records without CVE identifiers. Third-party polling is distinguished from owned-repository and demonstration events. Nine enrichment dimensions and six correlation functions preserve provenance and explain relationships. BM25, dense retrieval and graph expansion support explicit multi-hop plans, sentence-level citations and Critic validation. Dependency checking uses ecosystem-specific version semantics, distinguishing affected, no known impact and uncovered components. Nine agent roles exchange structured state, with PostgreSQL authoritative. Seven MCP tools, OpenAPI, CLI and plugins expose capabilities through eight Schemas and three extension points. PoC content is restricted to links, exposure data to counts; active scanning is excluded.

Completed observations cover connectivity and Ollama query calibration. On 14 October 2026, major sources returned HTTP 200 in the tested mainland-China environment; CNVD and arXiv failures prompted channel changes. Homepage reachability does not establish data-API functionality. At 15:57 on 15 October, a narrowed Quake query returned 172,411 worldwide and 51,612 for China. A separate 19:55 metadata sample matched 44 of 50 records: 88% precision, above the 80% threshold. These snapshots remain distinct and do not validate other components. End-to-end P95 latency is pending against a six-hour target; enrichment accuracy is pending against 95% on 200 gold records; citation correctness on approximately 100 questions is pending with its target undetermined. Continuous observation and controlled evaluation must establish system-level performance.

Keywords: AI security; threat intelligence; multi-agent system; knowledge graph; GraphRAG; Model Context Protocol

目录

概述 7
第一章 作品概述 10
1.1 背景分析 10
1.1.1 来源分散与时效缺口 10
1.1.2 多源分歧与关联证据 11
1.1.3 具体问题与开发流程 11
1.2 相关工作 12
1.2.1 漏洞情报数据库与交换标准 12
1.2.2 威胁情报平台与安全知识图谱 12
1.2.3 大模型与检索增强 12
1.2.4 智能体编排与互操作 13
1.3 作品特色 13
1.4 应用前景与市场价值 14
1.4.1 应用场景 14
1.4.2 市场价值 15
第二章 作品设计 16
2.1 系统总体架构设计 16
2.2 系统工作流程 17
2.2.1 端到端数据流 17
2.2.2 一条新公告的处理时序 19
2.2.3 查询类请求的处理流程 20
2.3 智能体方案设计 20
2.3.1 角色划分与协作关系 20
2.3.2 任务编排与状态管理 22
2.3.3 Critic 校验闭环 23
2.3.4 大模型调用策略 24
2.4 情报监测模块详细设计 25
2.4.1 数据源体系与可信度分级 25
2.4.2 分级轮询与实时通道 26
2.4.3 去重、合并与规范标识 27
2.4.4 典型来源的连接器设计 28
2.5 情报富化模块详细设计 29
2.5.1 九维富化 29
2.5.2 六类自动关联 31
2.5.3 多源冲突的逐字段裁决 32
2.5.4 版本自查 34
2.5.5 影响评估与处置建议 35
2.6 情报问答模块详细设计 35
2.6.1 三路混合检索 35
2.6.2 显式多跳推理与引用校验 36
2.6.3 多轮对话与中文支持 37
2.7 对外开放与插件生态设计 37
2.7.1 统一服务层与四种接入方式 37
2.7.2 七个 MCP 工具 38
2.7.3 开放 Schema 与插件扩展 39
2.8 关键技术选型说明 41

第三章 作品实现 44
3.1 系统实现细节 44
3.1.1 部署结构 44
3.1.2 数据模型与知识图谱 45
3.1.3 自愈与降级 46
3.1.4 可观测性实现 47
3.1.5 合规边界 47
3.1.6 境内网络连通性验证 48
3.2 核心代码说明 49
3.2.1 逐字段冲突裁决 50
3.2.2 版本区间求解 50
3.2.3 混合检索的倒数排名融合 51
3.2.4 Critic 引用校验 52
3.2.5 带抖动的指数退避与死信 52
3.2.6 长任务句柄 53
3.3 各功能模块实现效果展示 53
3.3.1 监测 态势大屏 54
3.3.2 富化 情报详情卡与关联图谱 54
3.3.3 问答 带引用的推理侧栏 56
3.3.4 自查 版本自查页面与命令行 56
3.3.5 编排 智能体任务树 57
3.3.6 开放 插件状态与编码智能体调用 58
第四章 测试与分析 60
4.1 测试方案与环境 60
4.2 监测时效测试 62
4.2.1 测试方法 62
4.2.2 测试结果 62
4.3 富化与关联准确率测试 63
4.3.1 金标集构建 63
4.3.2 评测协议与结果 64
4.4 问答质量测试 65
4.4.1 评测集与基线 65
4.4.2 评价指标与结果 65
4.5 编排可靠性与故障注入测试 66
4.6 编码智能体兼容性与已完成的工程验证 67
4.6.1 编码智能体兼容性 67
4.6.2 已完成的工程验证 67
4.7 对比分析 69
第五章 创新性说明 71
5.1 面向 AI 基础设施的垂直多源融合 71
5.2 可解释的自动关联推理引擎 72
5.3 从依赖文件出发的“我受不受影响”自查 72
5.4 可解释 GraphRAG 问答 72
5.5 内部多智能体编排与外部 MCP 开放统一 73
5.6 时效可观测与故障自愈 73
5.7 开放的插件生态 74
第六章 总结与展望 75
6.1 工作总结 75

6.2 不足与展望 75
参考文献 77
附录 A 数据源连通性实测 79
附录 B 测绘平台查询记录 80
附录 C 端到端运行追踪 82
附录 D 外部智能体调用实录 84
附录 E 性能与延迟原始记录 85
附录 F 故障与修复记录 86
附录 G 评测集与评测运行记录 88

概述

哨望用六层架构隔开变化快的来源接口、长期保存的事实和对外查询。PostgreSQL 为事实源，图谱与全文索引承担读取投影，可观测、可信裁决、合规与开放约束贯穿各层。（2.1）内部九个角色通过统一数据和任务状态交接，Critic 位于富化、评估、问答和报告的对外路径上，避免用自由对话替代可检查流程。（2.3）

监测以 P0 厂商五分钟轮询承接无编号公告，并区分第三方发现与 DEMO；富化保留字段分歧，为图边强制附理由与置信度；问答将精确词项、语义和关系路径结合，逐句引用后再校验。（2.4—2.6）选型采用有状态图、事实与向量同库、独立图投影及 MCP 双传输，各自说明替代项与维护代价。（2.8）

端到端数据流、公告时序和查询路径分别说明材料怎样进入系统、何时成为可查询事实以及长任务怎样续取，五段时间戳使阶段耗时可分辨。（2.2）实现部分组织单机容器、数据模型、降级通道、观测与合规边界；已完成的境内连通性记录与尚待完成的运行验证分开呈现。（3.1）

六段核心代码保留冲突裁决、版本求解、RRF、引用校验、退避和任务句柄的参考逻辑，并注明与最终实现需核对的差异。（3.2）功能展示按监测、富化、问答、自查、编排和开放排列九处截图，灰色框均为待补位置，不充当真实界面。（3.3）

性能评测先固定范围与对照：六小时只统计漏洞类首次发现，二百条金标覆盖困难关联，约一百题比较三种检索配置。端到端 P95 目标不超过 6 h，结果**【待测】**；富化准确率目标不低于 95%，结果**【待测】**；问答与自愈结果**【待测】**。已实测的 Quake 收窄与抽样另行报告，不能代替这些指标。（第四章）

创新围绕七项衔接展开：面向 AI 基础设施的垂直多源融合、可解释的自动关联推理引擎、从依赖文件出发的“我受不受影响”自查、可解释 GraphRAG 问答、内部多智能体编排与外部 MCP 开放统一、时效可观测与故障自愈、开放的插件生态。每项都对应前文设计和后文评测，证据不足处保留待测状态。（第五章）

图目录

图 1.1 监测—富化—问答闭环 14
图 2.1 哨望总体架构 16
图 2.2 端到端数据流与阶段时间戳 18
图 2.3 一条新公告从发布到可问答的时序 19
图 2.4 查询请求的处理路径 20
图 2.5 九个智能体的协作关系 22
图 2.6 任务状态机 23
图 2.7 Critic 校验闭环 24
图 2.8 九类数据源与三级可信度 25
图 2.9 各来源采集节奏与目标时延 27
图 2.10 去重与合并的三层处理 28
图 2.11 九维富化画像 30
图 2.12 六类自动关联 32
图 2.13 多源冲突的逐字段裁决 33
图 2.14 版本自查流程 34
图 2.15 三路混合检索与 GraphRAG 问答流程 35
图 2.16 多跳问答的推理链示例 36
图 2.17 MCP 与插件生态全景 38
图 2.18 插件生命周期 40
图 2.19 公开 Schema 与 OSV / STIX 2.1 / CSAF 2.0 的对应 40
图 2.20 技术栈分层 42
图 3.1 docker compose 单机部署结构 44
图 3.2 知识图谱数据模型 45
图 3.3 失败重试、死信重放与熔断降级 46
图 3.4 对外合规边界 48
图 3.5 态势大屏 54
图 3.6 情报详情卡 55
图 3.7 知识图谱视图 55
图 3.8 问答侧栏与推理步骤 56
图 3.9 版本自查页面 57
图 3.10 智能体任务树 57
图 3.11 插件与 MCP 状态页面 58
图 3.12 Claude Code 通过 MCP 调用 check_stack 59
图 3.13 命令行工具在持续集成中的使用 59
图 4.1 评测体系总览 61
图 4.2 时效统计的时间戳定义 62
图 4.3 各来源时延分布箱线图 63
图 4.4 暴露面计数的语法校准 68
图 5.1 七项创新点总览 71

表目录

表 1.1 哨望与典型方案的定位对比 15
表 2.1 九个智能体角色的职责划分 21
表 2.2 各类来源的采集方式与时效目标 26
表 2.3 九个富化维度及其来源 29
表 2.4 字段级裁决特例 33
表 2.5 MCP 工具一览 39
表 2.6 关键技术选型 41
表 3.1 境内网络连通性实测结果 48
表 4.1 测试环境 60
表 4.2 测试指标与设计目标 60
表 4.3 各来源时延统计 63
表 4.4 富化与关联准确率评测 64
表 4.5 问答质量评测结果（三组对照） 65
表 4.6 故障注入测试场景 66
表 4.7 编码智能体兼容性测试 67
表 4.8 暴露面查询语法校准记录（Quake，Ollama） 68
表 4.9 与相关方案的定性对比 69
表 A-1 境内入口实测初稿 79
表 A-2 境外补充观测与证据边界 80
表 B-1 Quake 查询快照记录 81
表 B-2 组件语法校准台账 81
表 C-1 真实与演示样本阶段追踪模板 83
表 D-1 客户端调用实录登记模板 84
表 E-1 性能运行环境登记模板 85
表 E-2 来源时延原始记录索引 85
表 F-1 已有失败与方案调整记录 86
表 F-2 故障注入运行登记模板 87
表 G-1 数据集标注登记模板 88
表 G-2 评测运行与错例登记模板 89

第一章 作品概述

AI 基础设施的风险不只存在于模型回答中，也存在于推理服务、模型加载、任务调度和依赖组件里。本章从已有案例解释为什么需要垂直情报，再说明哨望接在通用漏洞库、情报平台和检索问答之后的哪一段。作品面向防守方，目标是回答哪些问题与当前组件有关、证据是否可靠、可以采取什么处置。

1.1 背景分析

Ollama 的 CVE-2024-37032 是一个具体例子：模型拉取接口的 digest 校验问题导致路径穿越，在 Docker 默认部署条件下可能形成远程代码执行，修复版本为 0.1.34。对防守方而言，仅知道漏洞名称不够，还需要把部署组件、当前版本和修复公告连起来。[1]

ShadowRay 则提示争议信息也必须保留。Oligo 记录 Ray 的 CVE-2023-48022 未授权任务提交接口自 2023 年 9 月起遭在野利用，厂商对该编号存在异议。若系统只保留一句严重性描述，就会丢掉“谁确认、谁有异议、依据是什么”这些影响研判的信息。[2]

第三个例子来自 vLLM 的 CVE-2025-32444。Mooncake 集成中的 pickle 反序列化问题涉及 0.6.5 至 0.8.5 之前的版本，GHSA 给出 CVSS 10.0，NVD 为 9.8，OSV 还有 PYSEC-2025-42 标识。它同时要求跨源合并、保留评分分歧和版本求解，正好暴露了只按标题收集公告的局限。[3]

1.1.1 来源分散与时效缺口

AI 组件材料分散在 NVD、GHSA、OSV、厂商公告、专业披露平台和研究资讯中，厂商公开修复信息时可能还没有 CVE。等待一个数据库完成收录与分析，会把来源发布和防守方获知之间的时间拉长。NVD 自 2024-02-12 起放缓分析，说明权威来源也可能存在处理积压。[4]

VulnCheck 的历史统计中，截至 2024-05-20，12 720 个新增 CVE 有 11 885 个未分析，占 93.4%；到 2024-09-21，仍有 18 358 个、占 72.4%。十月初相关报道提到超过 17 000 个积压。它们描述的是当时的分析状态，不是哨望测出的延迟，也不能外推为当前所有来源的情况。[5][6][7]

2024 年 CVE 发布量为 40 009 个，高于 2023 年的 28 818 个，增长 38.83%。规模增加使人工逐源检查更难持续，但扩大收集范围也会引入重复与低可信材料。因此哨望同时采用分级轮询和来源等级，先接住新公告，再逐步补全编号和证据。[8]

1.1.2 多源分歧与关联证据

同一漏洞的不同评分不一定是某一方录错。vLLM 案例中的向量差异涉及作用域判断，只有保留原向量、来源时间和规则，用户才能理解主值为何被选择。直接用“取最高分”合并虽然简单，却改变了信息含义，也无法解释更低分的来源为什么没有被采用。[3]

关联还有另一层困难。编号别名可以由规则确认，论文讨论与 ATLAS 映射却常常需要语义判断。若两类边都画成同样的线，分析师就无法判断哪条是明确字段、哪条是模型推断。哨望把方法、理由、置信度和来源记录写进关系契约，并让弱关联经过 Critic。

这样的处理并不消除争议，而是让争议进入结构化记录。一级来源撤回、版本区间互斥和双 CVE 候选都有特定规则；未知与冲突保留为可见状态。第二章的逐字段裁决回应了这一挑战，第四章则以困难样本金标检验规则是否可靠。

1.1.3 具体问题与开发流程

防守方的问题通常包含多个约束：近九十天、某个组件、已有公开链接、对应某种技术、应该升级到哪个版本。单篇文章可能只回答其中一部分，向量相似度也不能自动证明版本落在影响范围。需要把文本证据、关系路径和版本规则组合起来。

开发者的工作位置又不总在情报网页。他可能在编码智能体里添加依赖，或在 CI 中检查提交；如果风险信息只能人工搜索，就难以进入这些环节。哨望因此将同一版本自查和问答能力通过 MCP 与命令行提供，让开发工具取得结构化结果和来源。

OWASP LLM Top 10、NIST AI RMF 及其生成式 AI 配套材料，为讨论 AI 风险提供参照；国内相关管理文件也构成作品定位的背景。本报告不把这些框架当作已经完成认证的依据，而是将它们作为风险分类与防御措施的参考材料。[9][10][11][12]

防御边界由此明确：不做渗透，不执行、保存或分发利用代码，不主动扫描第三方目标；暴露面只给聚合计数，PoC 仅给链接，接口默认只读。情报最终应帮助修补或防范，而不是提供可操作的攻击流程。[13]

1.2 相关工作

1.2.1 漏洞情报数据库与交换标准

NVD 提供漏洞记录接口，OSV 提供适合软件包与版本的结构，KEV 和 EPSS 从已知利用与预测风险两个角度补充排序信息。它们分别解决重要问题，但用户仍需把编号、版本、公告和处置放到一个具体组件上下文中理解。[14][15][16][17]

STIX 2.1 与 CSAF 2.0 规定交换对象和安全公告结构，使不同系统之间的数据不必依赖任意文本约定。哨望采用映射而不是另造封闭格式：可以表达的字段按标准输出，没有原生字段的关系理由与置信度通过扩展保留。映射范围与信息缺口需要公开说明。[18][19]

在这一基础上，哨望补的是垂直来源适配、字段级冲突和依赖判断。它不取代外部数据库的权威身份，也不把本地合并结果反写成外部官方结论。公告仍保留来源归属，主值只是按明确规则形成的当前展示结果。

1.2.2 威胁情报平台与安全知识图谱

MISP 的工作围绕协作式威胁情报共享，OpenCTI 提供开放的情报平台。它们说明结构化存储和关系组织可以支撑材料交换与研判；CWE、ATLAS 等知识体系则提供跨记录的分类连接。[20][21][22][23]

哨望关注的是这些能力在 AI 组件问题上的具体落点：一份厂商公告如何对应漏洞，漏洞如何对应软件包与区间，语义关联为什么成立。它要求每条边附理由和方法，使分析师能从图上的路径回到文本或字段。这里不据文献题名推断其他平台完全不具备类似能力，而是说明本作品将其设为必需契约。

CTIBench、CyLens 和 LLM 辅助情报推理工作表明，大模型辅助理解与评估是已有研究方向。本报告据此把模型参与限定在语义复核与弱关联等环节，同时用本任务的金标与问答集评测；不引用 dossier 未提供的数据规模或外部基准成绩作比较。[24][25][26]

1.2.3 大模型与检索增强

检索增强生成（Retrieval-Augmented Generation，RAG）把检索材料引入生成，GraphRAG 进一步关注图结构与查询相关组织。对本作品而言，这些思路提供了连接文本和关系的基础，但漏洞编号、版本边界和时间范围仍需要精确约束。[27][28]

IRCoT 的多步检索思路启发了显式子问题规划，ALCE 的引用质量思路提醒我们分别判断答案和证据。哨望将它们落实为可审计的检索步骤、逐句引用和返回前校验，并通过 RRF 组合不同召回结果。[29][30][31]

模型仍可能在证据不足时生成看似合理的句子。因此问答评价同时看答案、引用正确率与覆盖率，RAGAS 只作辅助。资料中的指令也不能获得系统权限，外部正文按不可信数据处理。这些限制是检索增强的使用条件，不能因为加入检索就省略。[32][33]

1.2.4 智能体编排与互操作

ReAct 讨论推理与行动的结合，AutoGen 讨论多智能体对话协作，LangGraph 提供有状态流程的组织方式。哨望的采集、归一、写入和版本求解大部分有确定规则，因此采用显式状态交接，让模型在有限节点承担语义任务。[34][35][36]

对外互操作采用 MCP，统一开放查询、自查、问答与任务续取。它解决的是编码智能体如何发现和调用服务，而内部状态图解决的是服务怎样完成工作。两者职责不同，共享事实与任务身份才能形成稳定衔接。[37]

A2A 面向更进一步的智能体协作，目前只列为规划。作品的当前定位是防御侧、可追溯的情报服务：先把来源、判断与证据组织清楚，再让外部工具能够按权限调用；不把协议扩展写成已经完成的多方协同。[38]

1.3 作品特色

及时发现并保留分歧。 厂商公告不必等到 CVE 分配才进入系统，规范编号可随别名补齐；新增来源同时带来可信度与逐字段裁决，不用一个覆盖值代替所有原始说法。这使“早知道”和“说得清”在同一流程里受到约束。

关联必须解释依据。 确定性关系由规则建立，弱关联附理由与置信度并经 Critic。用户沿图谱查看 ATLAS 或论文时，能知道关系来自明确字段还是语义判断；未达门槛的候选不伪装成事实。

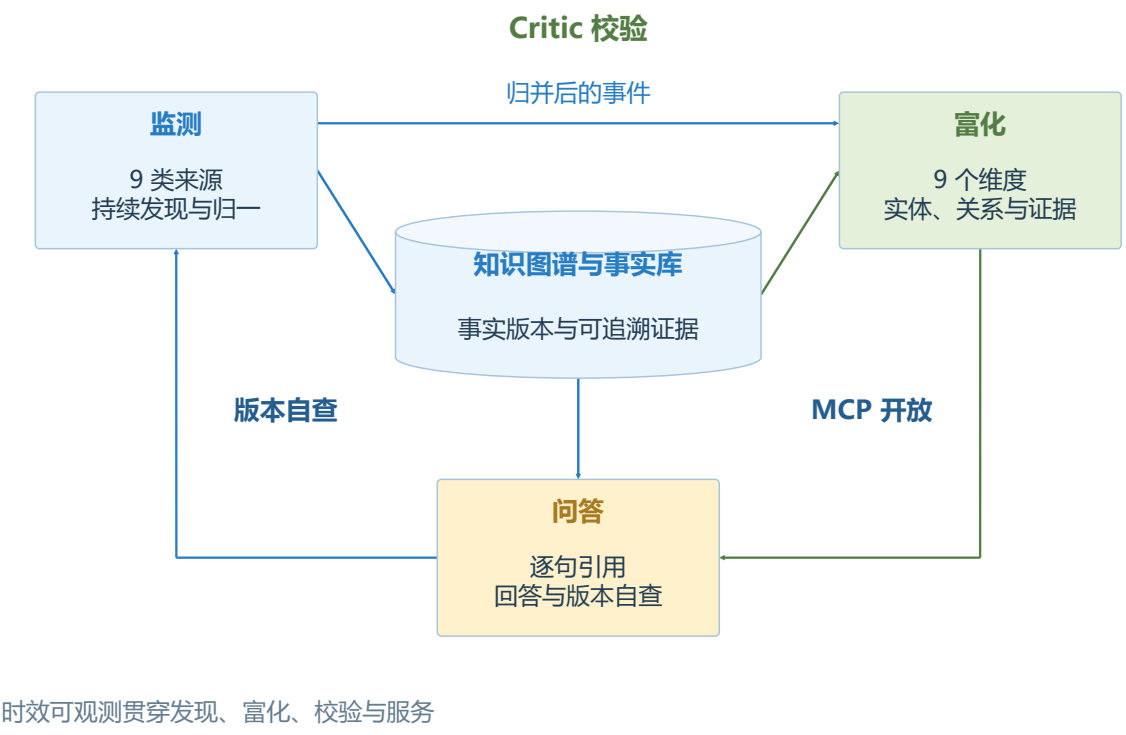


图 1.1 监测—富化—问答闭环

从项目清单回答影响。 版本自查以依赖文件为入口，按生态比较而非字符串比较，区分受影响、未发现已知影响和未收录。结果既可给分析师阅读，也可由 MCP 与 CI 使用，保持同一判断规则。

答案可追到证据路径。 三路检索与显式多跳把中间约束展开，逐句引用与 Critic 将不存在的证据、不支持的结论和越界内容分开处理。特色在于这些约束如何协作，实际质量仍由第四章待测结果检验。

1.4 应用前景与市场价值

1.4.1 应用场景

对企业安全运营团队，工作可以从大屏的一条新公告开始：先检查来源状态与发现时间，再进入详情卡看评分分歧，上传组件清单判断影响，最后按 KEV、EPSS、CVSS 与暴露面安排处理优先级。这是一条拟支持的工作路径，不是已完成用户试用的统计。

对 AI 应用开发团队，入口可以是编码智能体中的依赖问题。check_stack 返回关联漏洞与修复版本，get_vuln 展开依据，ask 回答需要跨文档解释的部分；CI 则根据

shaowang check 的退出码执行门禁。团队无需为每个来源编写不同解析逻辑，但实际接入仍需兼容性验证。

对安全研究与教学，图谱可沿 MAPS_TO 与 DISCUSSED_IN 观察漏洞、ATLAS 技术和论文的联系。关系方法与置信度有助于区分确定材料与研究线索，保留争议也便于展示研判过程。使用边界始终是知识理解和防御分析，不延伸到主动目标测试。

1.4.2 市场价值

作品的应用价值是减少材料转换：把分散公告转成统一事实，把统一事实转成具体版本判断，再把判断带回用户工作的工具。表中比较的是典型方案定位，不是对所有产品的功能审计，也没有投入回报或节省工时的实测。

表 1.1 哨望与典型方案的定位对比

对比维度	通用漏洞资料	情报平台路线	普通 RAG 路线	哨望设计
AI 组件覆盖	按来源收录规则	通过连接器组织	取决于语料	九类来源，承接无 CVE 公告
多源分歧	保留各源描述	依配置与流程处理	依检索与生成实现	逐字段裁决并保留冲突
关系依据	来源自带引用	结构化关系组织	文本证据召回	关系理由与置信度必填
版本判断	OSV 提供区间结构	需结合具体实现	需额外精确约束	依赖文件与生态区间求解
问答引用	提供事实材料	需结合问答实现	生成与检索结合	显式多跳，返回前校验
开发接入	API 等入口	依部署与扩展	依实现而定	MCP、OpenAPI、CLI、插件

这种价值能否兑现，取决于稳定覆盖、准确率和维护成本。来源改版、模型变化和测绘配额都会带来持续工作；公开插件接口有助于分担适配，但不能据此假定已有社区贡献。现阶段应先完成第四章评测与附录运行证据，再讨论更大规模应用。

第二章 作品设计

一条公告进入系统之后，怎样成为可以回答问题、检查依赖的证据？本章沿着这条路径展开设计。重点不在于把模型放进多少环节，而在于确定每一环节的输入、谁有权改变结论，以及失败后如何继续。六层架构负责隔离变化，九个智能体承担明确职责，监测、富化和问答则共享同一套事实与来源记录。

2.1 系统总体架构设计

数据源接口变化快，漏洞事实需要长期保留，对外工具又必须稳定。如果把这三类变化放进一个服务，来源页面的一次改版就可能牵动检索和客户端。哨望因此按数据源、采集、知识、智能体编排、服务和接入划分六层，用公开的数据结构隔开来源适配与业务判断。



图 2.1 哨望总体架构

数据源层提供原始材料，来源的权威性在这一层被标注，但不会直接转化为最终结论。采集层以 Source Connector 插件适配各来源；增量轮询与历史回填采用固定入口，插件变化只影响材料取得方式。自有仓库的 webhook 由平台接收并验签，再触发立即轮询，不把对外事件入口交给第三方插件。

知识层保留原文、归一事实和查询投影。PostgreSQL 16 是事实源，pgvector 保存语义向量；Neo4j 5 服务于关系路径，OpenSearch 2.x 服务于全文与编号检索；MinIO 保存原始载荷和报告。图库与全文索引通过 outbox 从事实源同步，不能因为它们查询方便，就让它们独立决定哪一条结论有效。

智能体编排层把各阶段组织成可恢复的有状态图，任务状态写入 agent_tasks。服务层将查询、自查和问答收拢到 intel-core，在此统一鉴权、限流、审计和结果裁剪。接入层再把同一能力交给 Web、模型上下文协议（Model Context Protocol，MCP）、OpenAPI、命令行和编码智能体插件包。外部界面可以变化，业务判断不随客户端复制。

四项横切约束贯穿六层。可观测性记录一条情报经过各阶段的时间；可信与冲突裁决保留每个值的来历；合规边界限制利用代码和资产明细外流；开放生态用 Schema、权限声明与签名索引约束扩展。它们不是完成业务以后再补的装饰，而是决定一条数据能否进入下一阶段的条件。

分层的代价是多出消息传递和索引一致性维护。哨望接受这一代价，是因为单一来源故障、模型替换和客户端升级不应互相拖累。公开 Schema 固定的是交接语义，具体连接器或模型可以替换；PostgreSQL 的权威地位则避免多个存储各自形成一套业务真相。

2.2 系统工作流程

2.2.1 端到端数据流

监测的终点不是下载成功，而是情报已经完成必要校验并可被查询。流水线因此划分为采集、归一、富化、校验、存储、服务六个阶段，并以五段时间戳记录从来源发布到系统可查询的过程。阶段和时间点并不一一对应：校验与存储的耗时仍包含在处理阶段内。

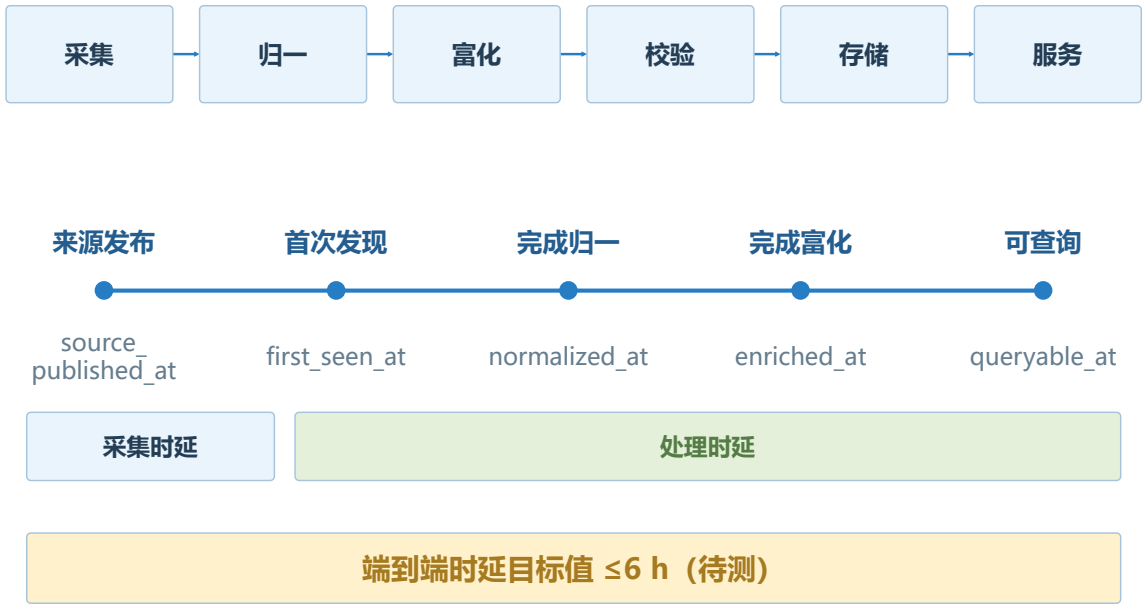


图 2.2 端到端数据流与阶段时间戳

Collector 发出带 ETag 或 If-Modified-Since 的条件请求，将原始载荷保存到 MinIO，并投递 RawEvent。首次看到同一来源的同一外部编号时记录 first_seen_at；内容哈希只用来判断原文变化，不能代替身份键。这样，公告修订时可以更新内容，同时保留“第一次发现”的时间含义。

Triage 先用关键词和组件字典判断是否与 AI 基础设施相关，再把边界情况交给模型复核。归一结果经别名合并后记录 normalized_at。Enricher 把九维画像拆成并行子任务，某一维失败只重试该维；完成富化时记录 enriched_at。Critic 检查后，由 GraphWriter 写入事实与投影，进入可查询状态时记录 queryable_at。

source_published_at 来自来源，不能用系统抓取时间冒充。采集时延是 first_seen_at 与来源发布时间之差，处理时延是 queryable_at 与 first_seen_at 之差，端到端时延则覆盖两者。这样的拆分可以回答“来源发现晚”还是“内部处理慢”，不会把模型排队造成的延迟归咎于轮询。

六小时目标只统计 NVD、GHSA、OSV、厂商公告和 huntr 的漏洞类首次发现。EPSS、论文和其他日更材料单列，自有演示注入条目也单列。统计口径先于结果冻结，防止用即时注入样本稀释真实来源的延迟。

2.2.2 一条新公告的处理时序

第三方仓库并不允许任意监测方安装 webhook。对 vLLM、Ollama 等 P0 厂商来源，设计采用五分钟增量轮询；“实时”在这里指分钟级发现，并不意味着所有来源都提供推送。P1 来源按三十分钟轮询，把有限调用配额优先留给关键组件。

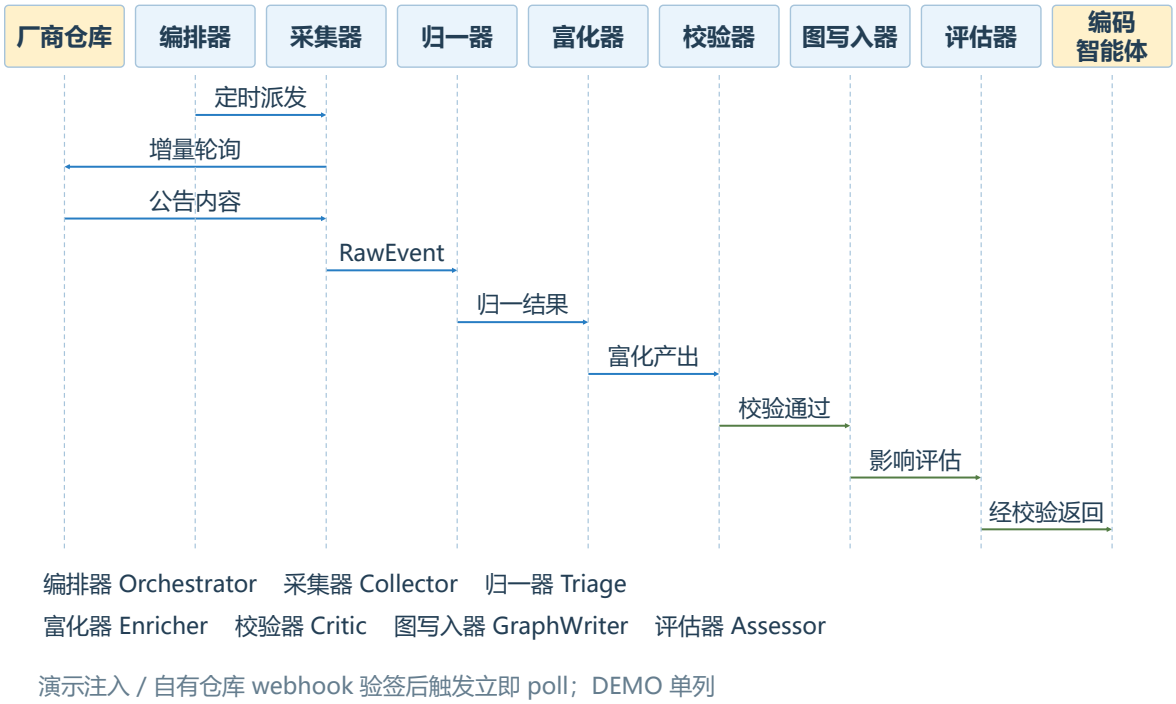


图 2.3 一条新公告从发布到可问答的时序

一次典型处理从 Orchestrator 派发轮询开始。Collector 取得公告，Triage 识别组件并生成归一记录，Enricher 补全画像，Critic 检查后才允许 GraphWriter 入库。新漏洞事件再触发 Assessor 判断风险和处置建议，对外产出仍需经过 Critic。时序中的每个箭头都对应数据或状态交接，而不是智能体之间的自由对话。

另一条路径用于自有仓库与答辩注入：平台验证事件签名后触发立即 poll，或由内部管理员调用演示入口。它与第三方轮询共用后续流水线，因此能演示归一、富化、校验的衔接；但它不能证明外部来源发现足够及时。演示数据带 DEMO 标记，统计默认排除。

厂商可能先发布修复版本，再补安全公告。Release 正文出现 security、CVE、GHSA、fix 等词时，会生成公告弱信号交 Triage。关键词命中只意味着需要复核，不等于已经确认漏洞，更不能直接触发高危告警。真正的时效结果为**【待测：漏洞类情报端到端时延 P95，目标值 ≤6 h】**。

2.2.3 查询类请求的处理流程

写入流程与查询流程分离。外部查询只读取已经通过 Critic 且写入 queryable_at 的数据；客户端调用异常不应中断采集流水线。以 check_stack 为例，请求先进入 intel-core，完成身份、scope、限流和审计检查，再解析依赖并求解版本区间。

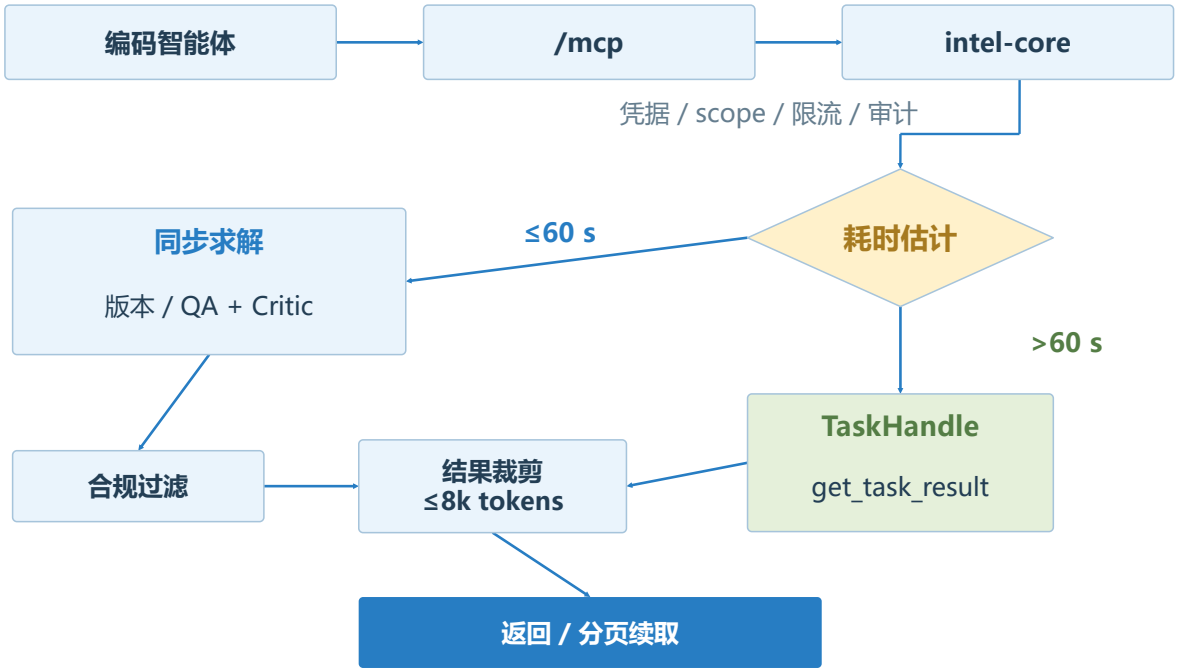


图 2.4 查询请求的处理路径

小清单可以同步完成，大于二百个组件或预计超过六十秒的请求转为异步。服务在执行前估计耗时，返回包含 task_id 和续取工具名的 TaskHandle，避免客户端等待到超时后又重复提交。结果保留二十四小时，调用方通过 get_task_result 读取。

同步与异步结果都要经过合规过滤和长度限制。单次结果不超过 8k tokens，列表超出时分页并返回 next_cursor 与截断标记。限制长度的目的不是删掉关键证据，而是让客户端知道还有什么没取完，能够继续读取而不把截断结果误当成全集。

2.3 智能体方案设计

2.3.1 角色划分与协作关系

情报处理包含大量确定性动作：抓取、别名合并、版本比较和存储都不需要模型自由发挥。九个角色按职责划分，智能体这一名称表示它在任务图中的责任，而不表示每次执行都调用大模型。输入输出固定之后，角色可以由规则、模型或插件实现。

表 2.1 九个智能体角色的职责划分

角色	输入	输出	关键约束
Orchestrator	定时器、自有仓库/演示注入事件、死信队列	任务 DAG 与状态（agent_tasks）	LangGraph 有状态图；按源设并发上限与令牌桶限速；SLA 超时告警
Collector	来源接口	RawEvent	每源一个插件；幂等键 (source, external_id)；content_hash 只做变更检测；不处理 webhook
Triage	RawEvent	NormalizedIntel	规则初筛 + 大模型复核；别名并查集；分到赛题四类风险与 ATLAS 候选
Enricher	NormalizedIntel	9 维富化结果	维度级并行与重试；每个字段带 provenance
GraphWriter	已校验记录	节点、边、向量、索引	upsert；每条边带 reason 与 confidence；outbox 保证最终一致
Assessor	new_vuln 事件	影响评估与处置建议	KEV 收录、EPSS > 0.5 或 CVSS ≥ 9 升为高危；只有三级来源的不升级
QA	自然语言问题	答案、推理步骤、引用	三路混合检索；逐句 [n] 引用
Critic	任一角色的产出	pass / reject（问答为 fail）/ partial	引用可回溯；LLM 产出 20% 抽检；置信度 < 0.6 不入图；金标集回归防漂移
Reporter	图谱与指标	日报、周报、告警、大屏指标	P50/P95 时延、源健康度、新增高危清单

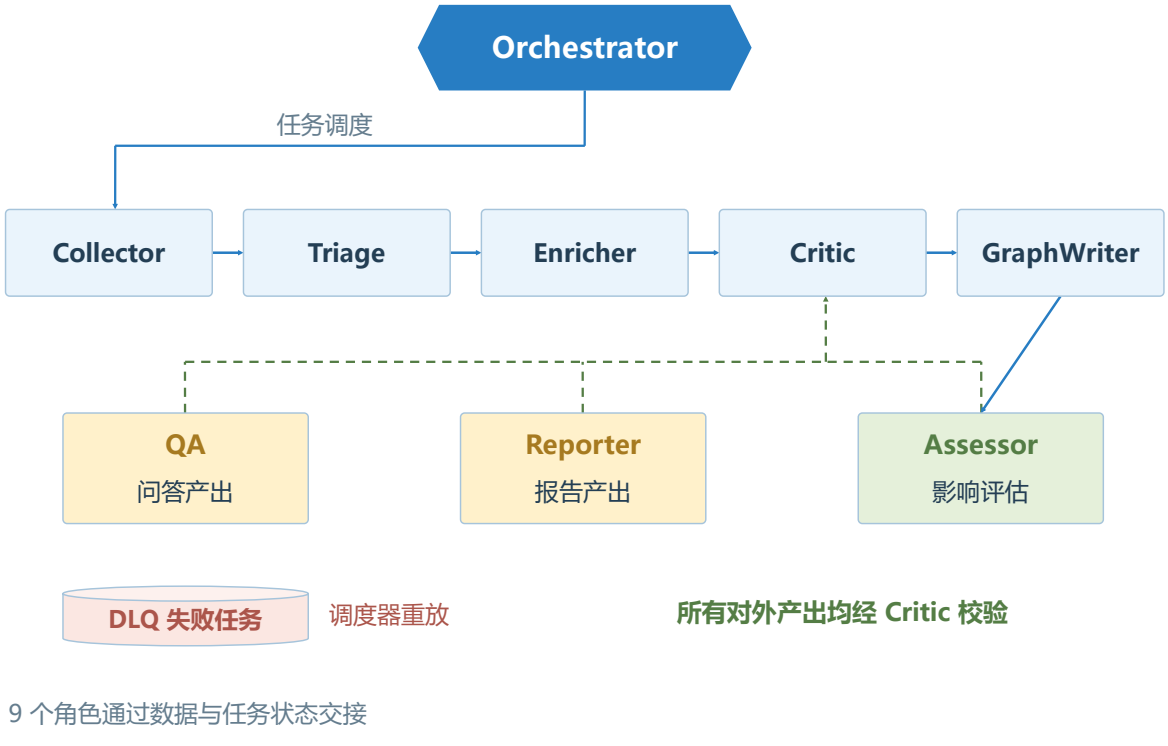


图 2.5 九个智能体的协作关系

Orchestrator 管任务和资源，Collector 管来源读取，Triage 管相关性与归一，Enricher 管字段补全，GraphWriter 管写入，Assessor 管风险与建议，QA 管问答，Critic 管检查，Reporter 管报告。把写图权集中到 GraphWriter，可以防止连接器或富化插件绕过校验直接改变知识图谱。

协作不依赖角色互相“讨论”。每一步交出统一格式的数据和任务状态，下一步据此继续。GHSA 的别名中明确包含 CVE 时，由规则建立关联；ATLAS 技术映射缺少直接字段时，才让模型参与判断并给出理由。确定性事实与模型推断从进入系统起就带有不同的方法标记。

Critic 位于所有对外产出的必经路径：富化入图、评估生效、答案返回和报告发布之前都需要检查。格式与一致性检查覆盖规则产出，大模型产出另按百分之二十抽检；这两层检查不能混写成“每项语义判断都已逐条人工验证”。角色职责是否落实，还需第三章参考实现和第四章运行评测共同提供证据。

2.3.2 任务编排与状态管理

一个慢任务不能只剩下“正在处理”四个字。LangGraph 有状态图记录步骤位置，agent_tasks 保存任务状态，使失败、等待与恢复都有可追踪的落点。任务从 queued 进入 running，成功后成为 succeeded，结果保留期满转为 expired。

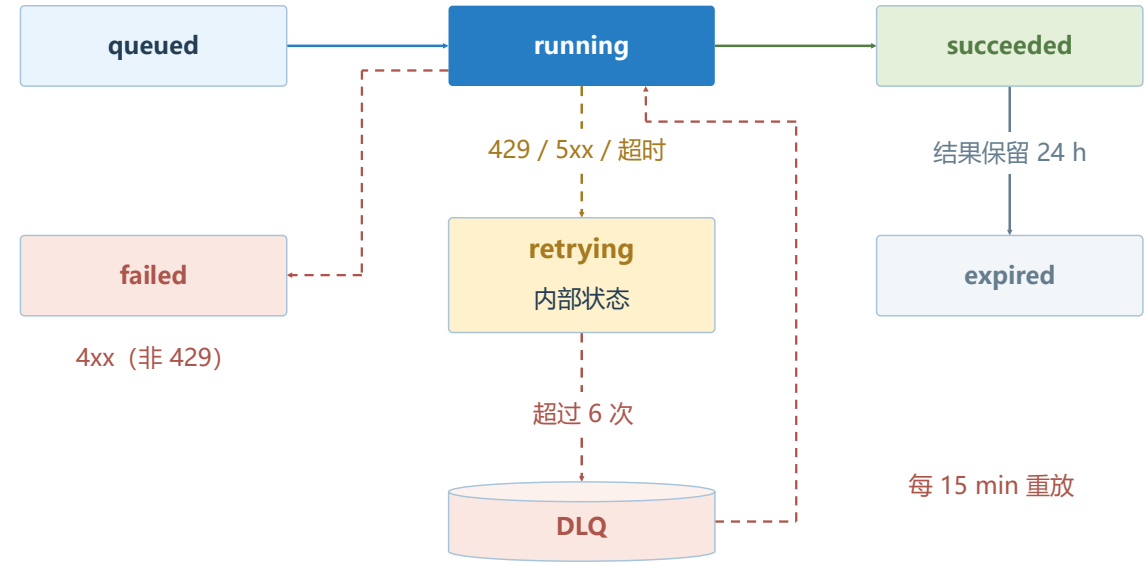


图 2.6 任务状态机

网络超时、限流和服务端故障进入内部 retrying；超过设计重试次数后进入死信队列，由 Orchestrator 每十五分钟重放。对外仍显示 running，客户端不用理解平台内部所有状态，但任务树必须保留原因，避免长期等待被误解为正常执行。

不可重试错误直接失败。来源级并发上限与令牌桶控制调用节奏，SLA 超时另行告警。它们解决的问题不同：并发限制避免同时压垮来源，限速约束单位时间请求量，超时告警则提示任务已经偏离服务目标。不能用增加重试次数替代对请求错误的修正。

2.3.3 Critic 校验闭环

生成结果附有引用，并不意味着引用支持结论。Critic 依次检查材料是否存在、内容是否支撑、输出是否越过合规边界。关系边还必须满足置信度门槛；低于 0.6 的弱关联不进入正式图谱，只能留作候选。

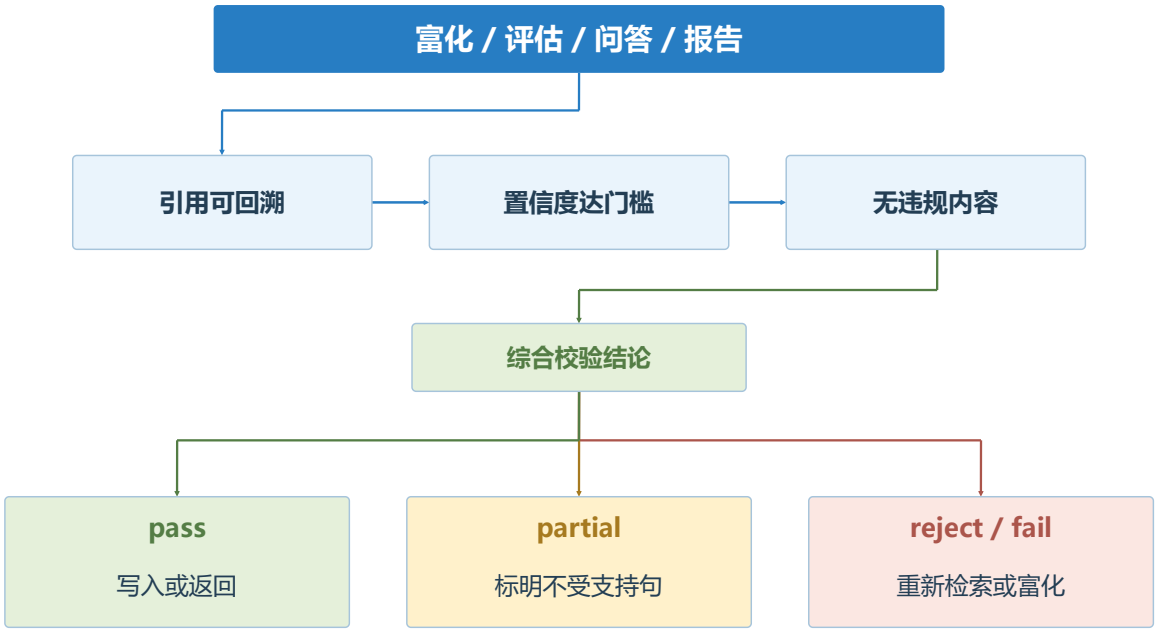


图 2.7 Critic 校验闭环

问答中任一引用指向不存在的文档，整个答案判为 fail。文档存在但不能支持某句话时，该句进入 unsupported_claims；不受支持句子的占比不超过百分之三十，可判 partial 并明确标注，超过则 fail。利用代码或资产地址一旦出现，直接判为不通过，不因其他句子有依据而放行。

驳回意见回到检索或富化环节，让上游补证据或修正判断。部分通过保留不确定性，而不是悄悄删掉失败句子后给用户一个完整可信的印象。Critic 自身也会误判，所以要用金标集校准，并同时观察拦截效果和误拦比例。其引用核验准确率为**【待测：Critic 引用核验准确率，目标值 xx%】**。

2.3.4 大模型调用策略

模型调用限定在四处：Triage 的相关性复核、Enricher 的弱关联判断、QA 的规划与生成、Critic 的支撑性判断。编号、版本和明确别名关系优先采用规则与数据库查询。把模型预算留给语义判断，可以减少等待，也让错误来源更容易定位。

每个插件和智能体设置每日用量预算，超额时降级为规则路径，并在任务树标明缺失能力。输出按 JSON Schema 校验，理由和置信度是必填内容；格式不合格视为失败，不能用空对象替代成功。模型给出的置信度还要经过 Critic 与金标集校准，不能把自报分数当作客观概率。

统一模型网关允许采用建议的 Qwen 或 DeepSeek API，也保留私有化部署替换路径。提示词和输出 Schema 带版本，模型更换后重跑金标集与问答集；Langfuse 记录调用过程。这里的可替换性是一项设计约束，尚不能据此宣称不同模型已经得到等价结果。

2.4 情报监测模块详细设计

2.4.1 数据源体系与可信度分级

来源数量解决覆盖问题，可信度分级解决采用什么结论的问题。九类来源覆盖漏洞数据库、开源安全公告、厂商材料、专业披露、风险指标、博客、论文、国内漏洞来源和标准法规；一个来源提供多个接口，不会因此增加来源类别数。测绘平台用于暴露面富化，也不另算一种监测来源。

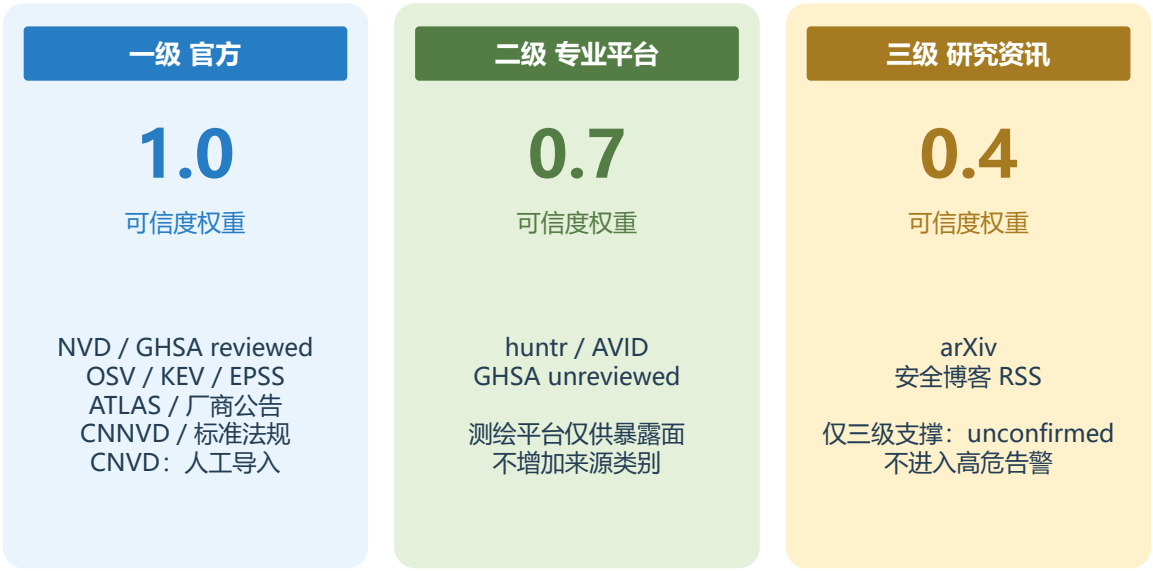


图 2.8 九类数据源与三级可信度

一级包括官方数据库、编号机构、政府与厂商，权重 1.0；二级包括有审核流程的专业平台，权重 0.7；三级为研究资讯，权重 0.4。GHSA reviewed 与 unreviewed 分属不同等级，说明等级针对材料的审核状态，不能只看平台名称。

等级参与字段裁决，却不能替代内容判断。只有三级材料支撑的记录标为 unconfirmed，不进入高危告警；问答同时提示它尚未得到官方确认。插件可以声明来源等级，平台审核只能下调，不能通过安装插件把普通资讯升级成官方事实。

2.4.2 分级轮询与实时通道

让所有来源采用同一频率既浪费配额，也会掩盖来源的更新规律。厂商安全公告需要尽早发现，EPSS 与论文通常按日更新，标准文档更适合版本监测。轮询计划据此分层，目标 P95 是设计要求，表中没有任何已完成性能测量的含义。

表 2.2 各类来源的采集方式与时效目标

来源	采集方式	频率	目标 P95 时延
自有仓库与演示注入	webhook 触发立即轮询	事件	≤1 min
厂商 GitHub 公告（第三方）	增量轮询	P0 5 min，P1 30 min	P0 ≤10 min，P1 ≤40 min
GHSA	增量轮询	10 min	≤15 min
NVD	按修改时间增量轮询	10 min	≤30 min
OSV	增量比对	15 min	≤30 min
安全博客 RSS	条件请求轮询	10 min	≤30 min
huntr	页面抓取	1 h	≤2 h
CISA KEV	全量比对	1 h	≤2 h
AVID	仓库增量拉取	6 h	≤6 h
EPSS、arXiv、CNNVD	日更批处理	1 d	≤24 h（日更类，单列）
CNVD	人工或半自动导入	不超过每周	不计入
标准法规	版本监测	1 周；ATLAS 每日检查	—

轮询频率	来源与触发方式	发现时延目标（待测）
事件	自有仓库 / DEMO	≤1 min
5 min	P0 厂商公告	≤10 min
10 min	GHSA / NVD / RSS	≤15 / 30 / 30 min
15 min	OSV	≤30 min
1 h	huntr / KEV	≤2 h
6 h	AVID	≤6 h
1 d	EPSS / arXiv / CNNVD	≤24 h
1 周	标准法规 / CNVD	版本监测 / 人工

6 h 口径：NVD、GHSA、OSV、厂商公告、huntr 首次发现；其余单列

图 2.9 各来源采集节奏与目标时延

NVD、GHSA 和 RSS 的基础间隔为十分钟，OSV 为十五分钟，huntr 与 KEV 为一小时，AVID 为六小时。P0 厂商公告五分钟、P1 三十分钟；EPSS、arXiv 和 CNNVD 按日处理，标准法规按周监测，ATLAS 数据仓库每日检查。CNVD 是人工或半自动导入路径，不能包装为自动实时采集。

六小时端到端目标与各来源采集目标是两套相关但不同的指标。前者从来源发布算到可查询，后者用于约束发现阶段。即使 P0 采集达到十分钟目标，后续富化排队也可能让端到端不达标；因此第四章分别给出阶段和总体结果。

2.4.3 去重、合并与规范标识

同一漏洞可能先出现在厂商公告，随后获得 GHSA、OSV 和 CVE 标识。如果每次都新建漏洞，分析师会重复处理；如果仅凭标题相似就合并，又可能把不同问题压成一条。哨望用三层策略区分“同一记录的重放”“明确别名”和“相似线索”。

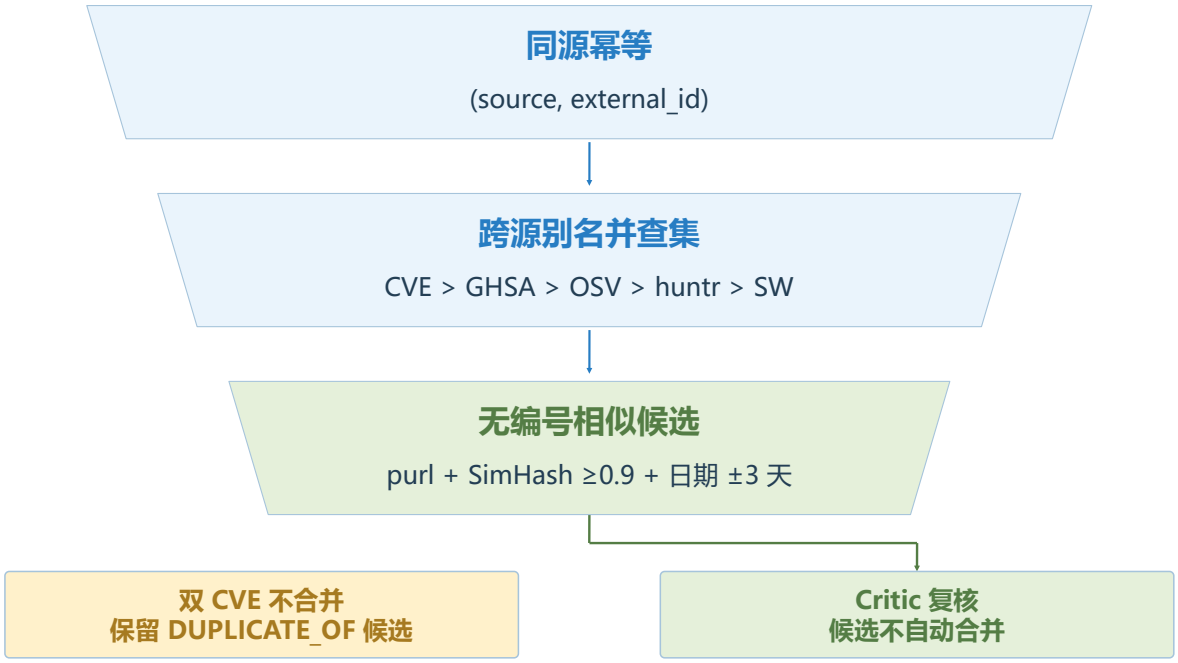


图 2.10 去重与合并的三层处理

同源幂等键是 source 与 external_id 的组合。跨源合并读取明确的 aliases 或 CVE 对应关系，用并查集维护连通关系；规范展示标识按 CVE、GHSA、OSV、huntr、SW 的顺序选择。没有外部编号时仍可用 SW-YYYY-NNNN 入库，不必等待编号分配。

没有明确别名时，只在组件 purl 相同、标题 SimHash 不低于 0.9、发布日期相差不超过三天的条件下生成候选，再交 Critic 复核。候选不会自动合并。别名同时指向两个不同 CVE 时，也只生成 DUPLICATE_OF 候选，保留歧义比制造一个错误的“统一编号”更稳妥。

2.4.4 典型来源的连接器设计

NVD 的难点在于更新与补全并不同步。连接器按 lastModified 增量拉取，窗口向前重叠五分钟，单次窗口不超过一百二十天、每页不超过二千条；重叠部分由幂等键去重。CVE 首见和评分补全分别记录，评分暂缺时可由 GHSA、OSV 补充，不能把缺评分误写成没有漏洞。接口长期不可用时转向 cvelistV5。[14]

GHSA 与 OSV 的价值不只在于多一个来源。GHSA 提供别名和公告线索，限流等待以响应头为依据；OSV 保留结构化版本区间，后续自查使用其事件语义，不能在归一时压成一句“低于某版本”。OSV 的增量入口不可用时，设计保留每日全量导出的降级路径。[15]

厂商连接器关注仓库级公告与 Release。仓库关闭 Security 页面或返回 404 时，改读 releases.atom 并筛出安全相关弱信号。公开披露平台 huntr 没有公开 API，按小时解析披露页面并遵守站点规则；失败后通过 GHSA、NVD 引用间接发现，同时标记来源降级，而不是宣称原连接器已经恢复。

论文与国内来源体现另一类约束。arXiv 采用 RSS 主通道、export API 补漏、Semantic Scholar 备用；CNNVD 计划每日只采编号、标题、等级、日期和链接等元数据，频率不高于五秒一次。CNNVD 数据接口仍待确认，CNVD 不做验证绕过，人工导入状态向 list_sources 公开。替代通道可用与原通道恢复必须分别记录。

2.5 情报富化模块详细设计

2.5.1 九维富化

单独一条漏洞描述不足以决定处置顺序。严重程度、在野利用、组件版本、研究背景和暴露规模分别回答不同问题，所以画像拆成九个维度，各维度保留来源和生成方法。某维度失败不应阻止其余已有证据供用户阅读，但缺失状态必须可见。

表 2.3 九个富化维度及其来源

#	维度	主要来源	方法与约束
1	CVSS	NVD、GHSA、CNNVD 等级	多源评分全部保留，按 D6.4 裁决主值，详情卡并列展示向量串
2	EPSS	FIRST EPSS	每日更新，用于排序
3	KEV	CISA KEV	只有 KEV 能置位在野利用标志（取并集，不撤销）；三级来源的“在野”说法只作 exploitation_rumor 提示
4	CWE	NVD、GHSA、规则映射	CNNVD 漏洞类型经规则映射，低置信
5	ATLAS	MITRE ATLAS	关键词规则召回候选 + 大模型选最匹配项，须过 Critic
6	受影响与修复版本	OSV、GHSA、厂商公告	OSV 区间结构（introduced / fixed / last_affected / limit）
7	相关论文与文章	arXiv、安全博客	嵌入相似度 + 组件共现，弱关联

#	维度	主要来源	方法与约束
8	PoC 与检测模板存在性	公开仓库、检测模板库	只存 PocRef{url,title,kind,source}；API 层再过滤代码块与 payload
9	公网暴露面	Hunter、Quake（首选），FOFA、ZoomEye（备选）	只存 provider、query_id、total、by_country、by_version、vulnerable_estimate、measured_at、ttl_sec；Schema additionalProperties:false；输出层 IP/域名正则拦截

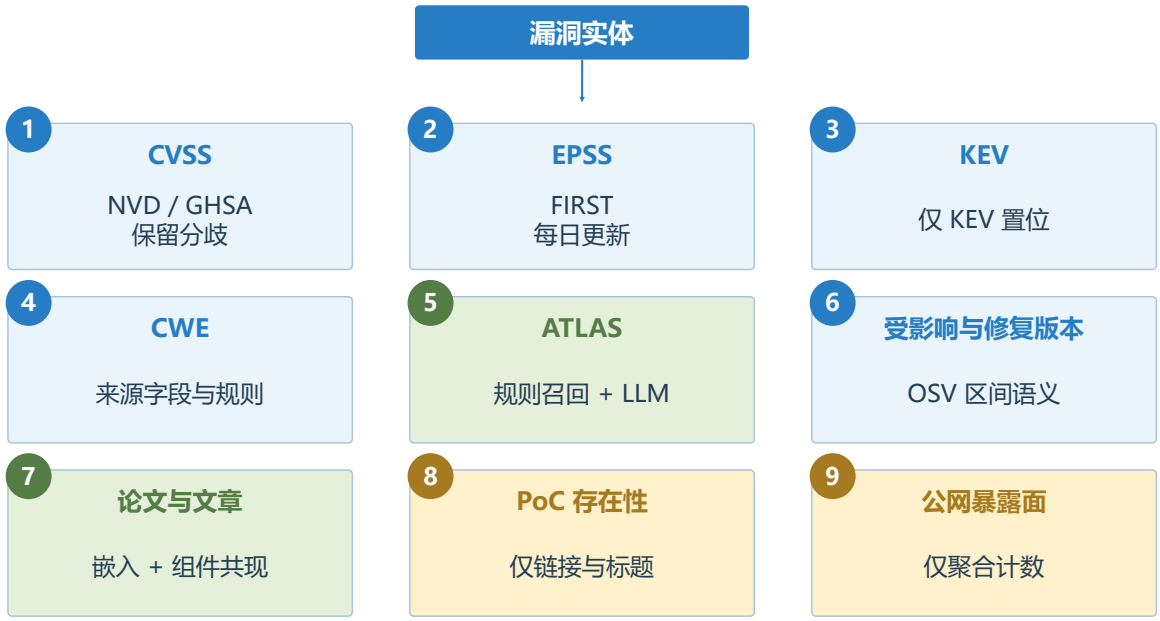


图 2.11 九维富化画像

通用漏洞评分系统（Common Vulnerability Scoring System，CVSS）描述严重程度，漏洞利用预测评分系统（Exploit Prediction Scoring System，EPSS）用于排序，已知被利用漏洞目录（Known Exploited Vulnerabilities，KEV）提供在野利用标志。三者不能互相替代：高评分不是已遭利用的证明，预测概率也不是具体事件记录。只有 KEV 能设置在野利用标志，三级报道只能作为传闻提示。[16][17]

通用弱点枚举（Common Weakness Enumeration，CWE）和 AI 对抗威胁知识库 ATLAS 提供分类视角；版本维度连接具体依赖；论文与文章帮助解释风险背景。

ATLAS 和论文关联中的模型判断属于弱关联，必须附理由与置信度。公开概念验证（Proof of Concept，PoC）这一维只记录是否存在链接、标题和类型，不保存或执行代码。[23][22]

暴露面只读取聚合计数，元数据校准只查看标题、端口和响应特征，不向目标主动发包。每组件抽样五十条，精确率达到百分之八十后才标为 verified；宽口径只作 upper_bound，不进入大屏和富化主值。来源、测量时间和快照始终随计数展示，不同平台的数值不相加、不平均。

Ollama 的 Quake 收窄查询已有实测：2026-10-15 15:57 全球 172 411、中国 51 612；同日 19:55 的五十条元数据抽样中四十四条符合条件，精确率 88%，达到语法上线门槛。计数与抽样是两次记录，抽样时平台总数为 172 401。完整过程见 4.6.2；这项结果不能代替其他组件的语法校准。

组件级缓存让同一组件的多个漏洞共享一次查询，新 KEV 或 CVSS 不低于 9 的漏洞允许插队刷新一次。Hunter 可用且通过校准后优先，未实测前采用 Quake。版本覆盖不足 0.3 时不展示受影响版本估计，避免把总暴露量写成可被某个漏洞影响的数量。

2.5.2 六类自动关联

关系图的价值在于把“同一个问题”“影响哪个组件”“对应什么技术”和“该如何处理”连起来。六类自动关联分别是多源合并、组件影响、ATLAS 映射、论文与文章关联、处置关联、版本求解。其中有持久化图边，也有运行时计算，不能把六类业务关联机械理解为六种边名。

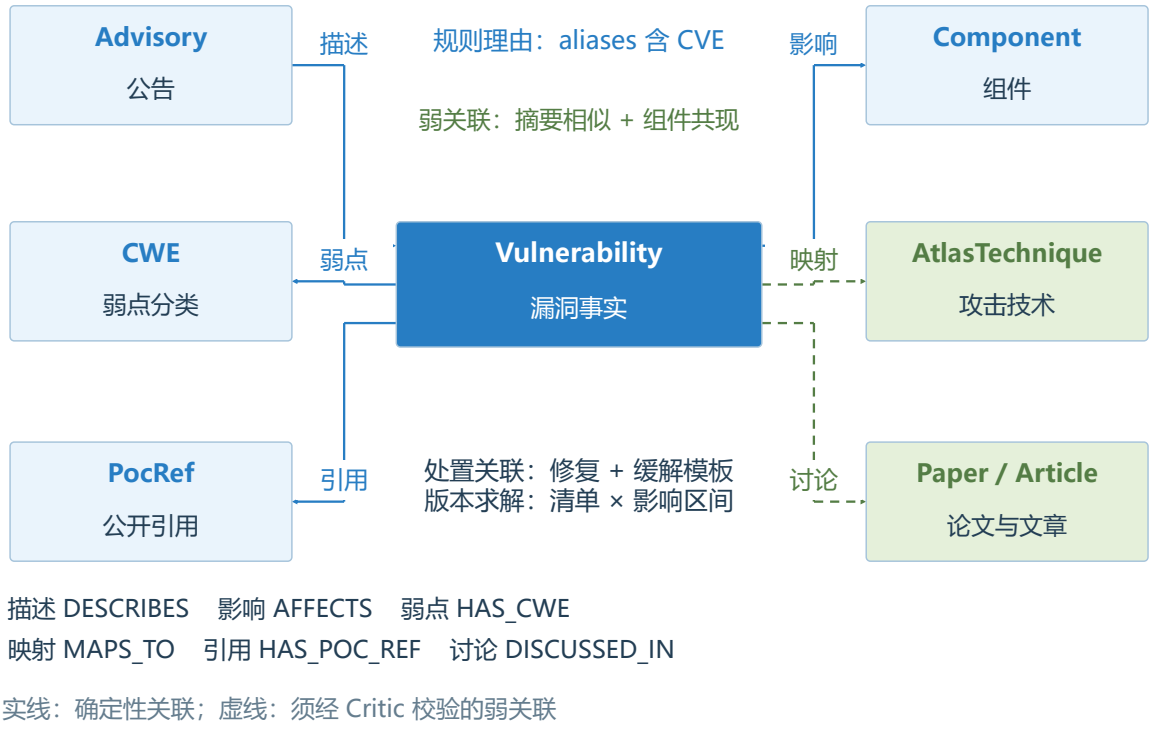


图 2.12 六类自动关联

公告通过 DESCRIBES 指向漏洞，漏洞通过 AFFECTS 指向组件，区间与修复信息随影响关系保存。MAPS_TO 指向 ATLAS 技术，DISCUSSED_IN 指向论文或文章；HAS_CWE、HAS_POC_REF、IN_CATEGORY 和 GOVERNED_BY 补充分类、引用与规范关系。处置建议由修复版本和缓解模板形成，版本求解则把用户清单与 AFFECTS 区间相交。

每条边必带 reason、confidence、method 和 created_by_agent。分析师点击关系时，应看到“公告的 aliases 包含该编号”这样的可核对理由，而不是只有“相关”二字。规则边可以直接回溯字段，模型边则显示候选依据和校验结论；可解释性由数据约束保证，再由界面呈现。

2.5.3 多源冲突的逐字段裁决

vLLM CVE-2025-32444 在 GHSA 与 NVD 中分别出现 10.0 和 9.8。选定一个主值便于排序，却不能抹掉另一方的向量与判断。冲突处理因此以字段为单位：同一漏洞的版本、评分和中文描述可以来自不同来源，每个胜出值各自携带 provenance。[3]

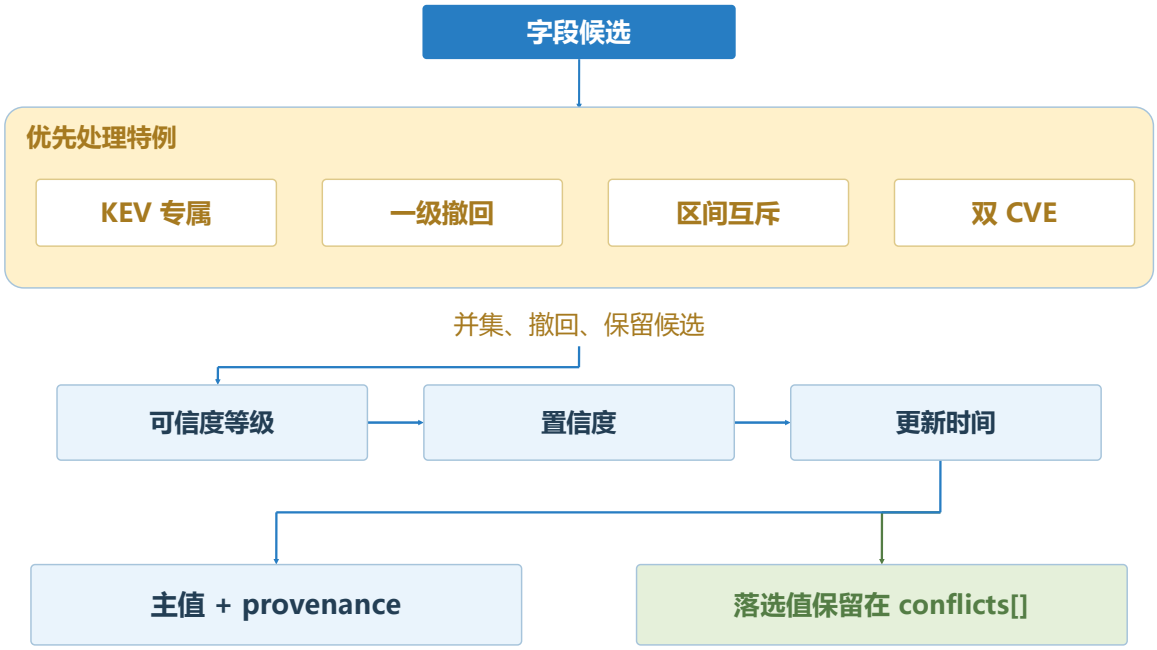


图 2.13 多源冲突的逐字段裁决

表 2.4 字段级裁决特例

字段情形	处理规则	保留信息
在野利用	只有 KEV 设置；取并集，不撤销	其他来源仅作传闻提示
一级来源撤回	任一一级来源撤回即 withdrawn	撤回来源与时间
一级版本区间互斥	取并集，标 conflict=true	原区间与自查分歧提示
别名指向两个 CVE	不自动合并，生成 DUPLICATE_OF 候选	两个编号及复核依据

四类特例先于普通排序：在野标志只由 KEV 设置；任一一级来源撤回即撤回；两个一级来源的版本区间互斥时取并集并提示冲突；别名指向双 CVE 时不自动合并。它们表达的是字段权限和风险边界，不能被“更新时间更晚”覆盖。

其余候选依次比较可信度等级、置信度和来源修改时间。集合字段先并集，中文描述只在国内来源与翻译之间裁决，EPSS 取 FIRST 最新值。落选值连同裁决规则进入 conflicts，详情卡和 get_vuln 都能展示。对两个一级 CVSS 值，必须知道实际修改时间才能决定主值，本报告不凭分数高低替它们做选择。

这套规则让分歧可见，但规则明确不代表已验证准确。金标集要覆盖错误合并、区间冲突和弱关联，结果为**【待测：富化与关联准确率（200 条金标集），目标值≥95%】**。保留候选与裁决记录，也是以后发现规则错误时重新计算的前提。

2.5.4 版本自查

用户真正关心的是项目里的版本，而不是数据库里总共有多少漏洞。自查接收组件清单，或 requirements.txt、pyproject.toml、package.json、go.mod、docker-compose.yml，解析为包标识 purl 与生态，再使用相应的版本比较规则求解。[15]

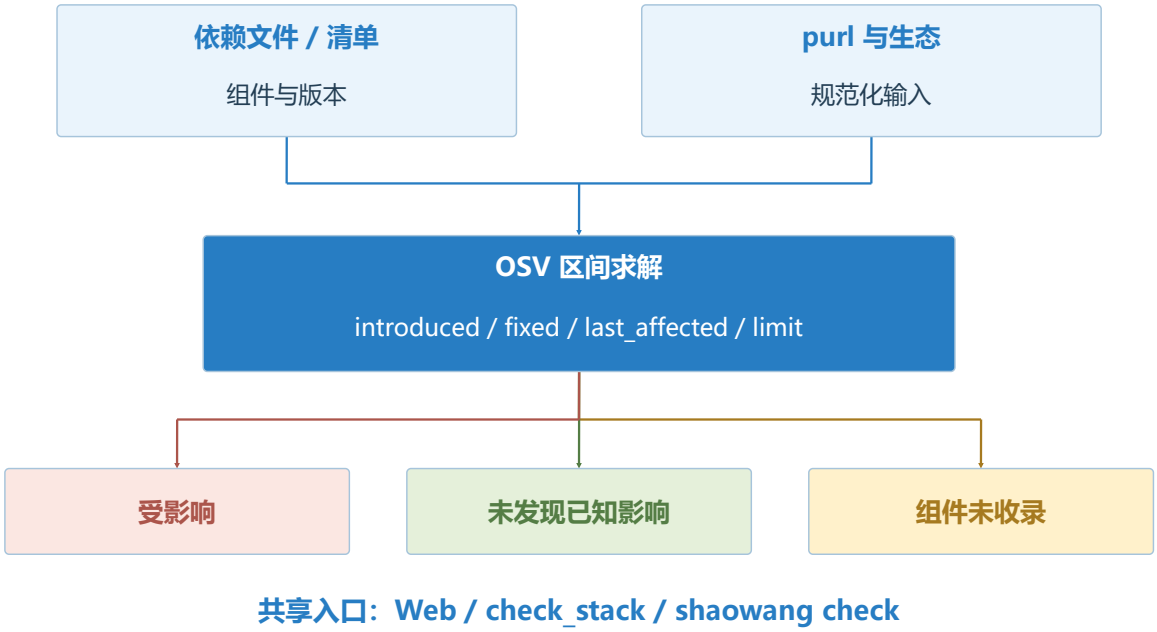


图 2.14 版本自查流程

OSV 用 introduced、fixed、last_affected 和 limit 描述区间事件，能够表达多次引入与修复。Python、JavaScript 和 Go 的版本规则并不相同，不能统一按字符串排序。来源对区间有分歧时，自查结果要同时提示，避免并集后的保守判断看起来像毫无争议的事实。

对外区分“受影响”“未发现已知影响”“组件未收录”。后两者尤其不能合并：前者表示在已有知识范围内未命中，后者表示覆盖不足。Web、MCP check_stack 和 shaowang check 共用求解能力；命令行发现高危时返回退出码 1，可供持续集成（Continuous Integration，CI）门禁使用，但实际集成效果仍待截图和调用记录确认。

2.5.5 影响评估与处置建议

评估规则要求用户能够看懂为什么被提到优先队列。KEV 收录、EPSS 大于 0.5 或 CVSS 不低于 9 时升级为高危；仅三级来源支撑的记录例外，不因媒体描述激烈就升级。告警理由可以直接说明触发条件，便于分析师复核。

处置建议分为官方修复与通用缓解。修复版本来自裁决结果，有一级来源分歧时一并提示；缓解模板按 CWE 与 ATLAS 关联，例如限制模型文件来源、关闭不必要的远程加载接口，或为推理服务启用认证代理。模板不是已验证修复，建议仍须经过 Critic，不能把一般防范措施写成某漏洞必然已经消除。

2.6 情报问答模块详细设计

2.6.1 三路混合检索

漏洞问题经常同时包含精确编号和自然语言意图。仅向量检索可能混淆相似版本，仅关键词又容易漏掉不同表述；跨文档问题还需要找出文本上不相似的关系证据。哨望组合 BM25、向量和图扩展三路召回，各自承担不同任务。[27][28]

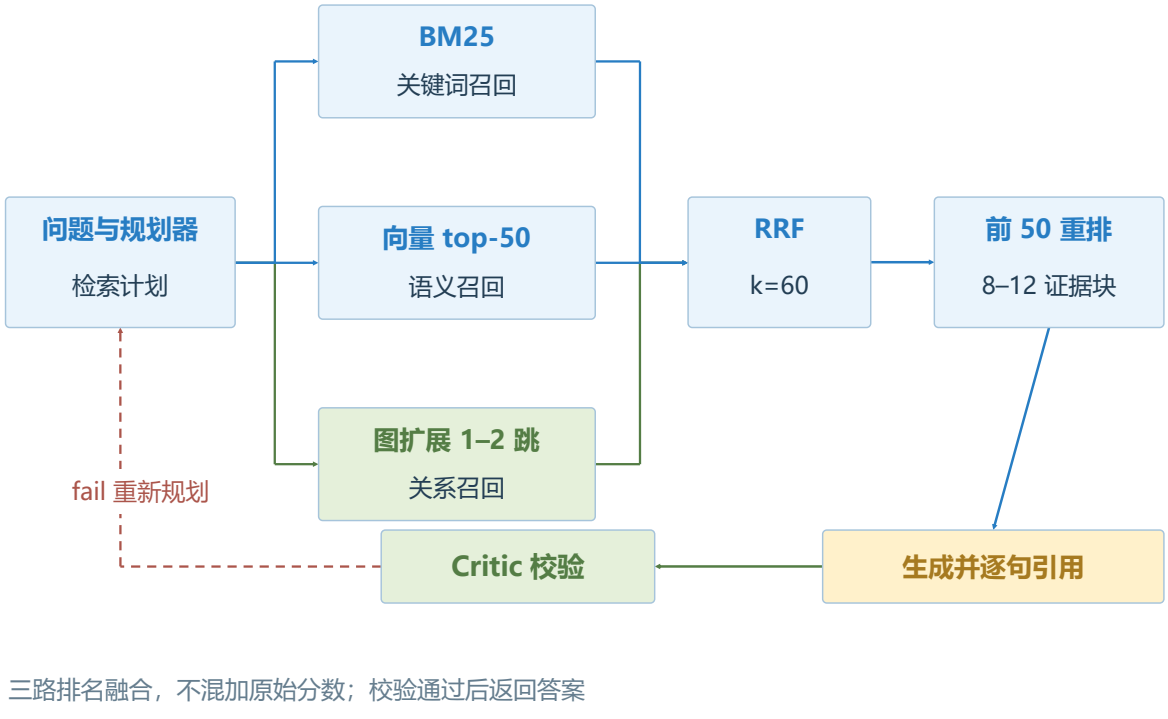


图 2.15 三路混合检索与 GraphRAG 问答流程

BM25 使用 OpenSearch 与 IK，保留组件名、编号和版本词项。bge-m3 与 pgvector 提供语义召回，取前五十项；图扩展从识别出的实体出发走一至两跳，取得

修复版本或同一 ATLAS 技术下的相关材料。图边不是证据文本的替身，返回结论时仍需落到可引用片段。[39]

三路原始分数没有统一尺度。倒数排名融合（Reciprocal Rank Fusion，RRF）只比较排名，将各路的 1 /（60＋名次）累加；同时被多路召回的候选因此得到更多支持。融合后取前五十个候选交 bge-reranker 重排，保留八至十二个证据块，在中间证据与上下文噪声之间取得设计上的折中。[31]

这套方案仍需要对照实验。图扩展可能带回更多材料，也可能引入无关关系；重排与 Critic 会增加处理时间。第四章采用同模型、同提示的三组配置比较质量，不能仅因为结构更复杂就认定结果更好。

2.6.2 显式多跳推理与引用校验

“近九十天影响 vLLM、已有公开 PoC 链接的漏洞分别对应什么 ATLAS 技术”包含四种约束。规划器先沿 AFFECTS 找漏洞，再沿 HAS_POC_REF 筛选链接，按发布时间过滤，最后沿 MAPS_TO 找技术。每步记录子问题、检索方式、查询语句与命中数，让用户看到答案依据如何组成。[29]

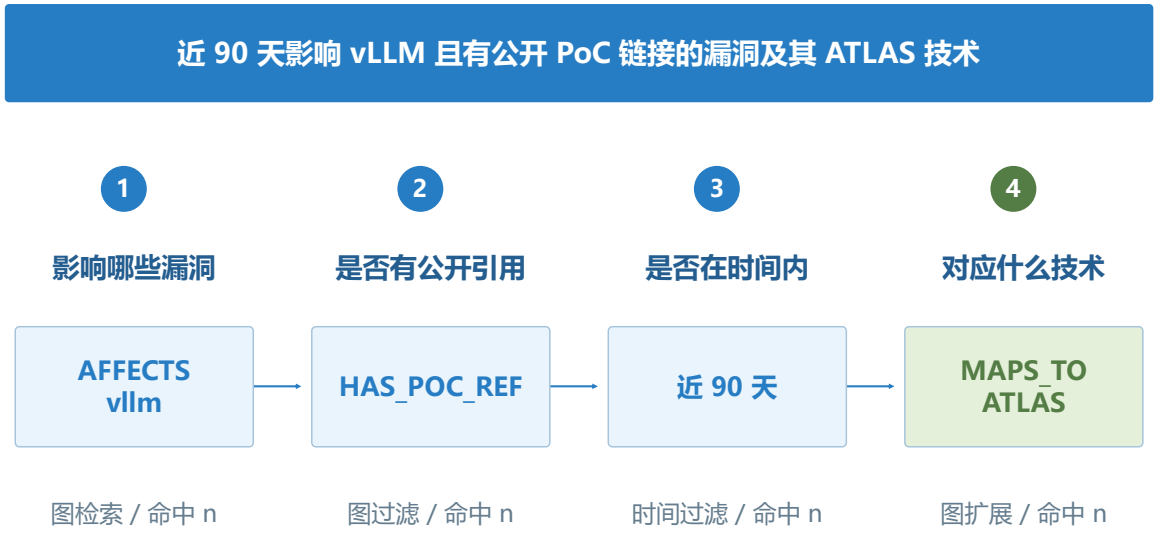


图 2.16 多跳问答的推理链示例

这里公开的是结构化检索计划与证据路径。若某一步没有命中，后续回答应说明缺口；不能让模型凭相邻概念补出一条看似连贯的路径。答案中的结论句带引用，

引用指向证据块并携带来源等级，使“找到了文档”与“文档支持结论”能够分别核验。[30]

Critic 对引用做存在性、支撑性和合规性检查。不通过时携带意见重新规划，有限次数后保留当前最好答案并标明置信度和未支持部分；重试次数尚未在材料中量化，不能在报告中擅自给出数值。答案与引用质量分别为**【待测：100 题评测集答案准确率，目标值 xx%】**、**【待测：100 题评测集引用正确率，目标值 xx%】**。

外部文章作为不可信材料进入 untrusted_text，不能拼成系统指令。对索取利用脚本或暴露资产地址的请求直接拒绝，返回防御侧的风险与处置信息。这样，即使检索材料中含有指令式文字，它也只是待分析内容，不获得控制工具和权限的地位。[33]

2.6.3 多轮对话与中文支持

多轮对话需要记住“其中”指哪些漏洞、“这个版本”指哪个组件，但不必把之前完整答案反复拼回提示。会话只保留实体与关键约束，后续问题据此消解指代，再重新检索证据。这样可以减少旧答案里的未证实描述被循环引用。

中文检索由 IK 分词和保留英文词项配合，bge-m3 负责跨语言语义召回；中文描述优先采用 CNNVD，缺失时再翻译。答案按提问语言生成，引用保留原文。翻译帮助阅读，却不能提高来源等级，也不能替代原文中缺失的修复结论。

2.7 对外开放与插件生态设计

2.7.1 统一服务层与四种接入方式

情报只有留在网页之外，才能进入依赖选择、代码审查和流水线。MCP、OpenAPI、命令行和插件包共用 intel-core，避免每个入口单独实现版本判断。四种开放方式与 Web 展示共同建立在统一服务层上，Web 不另算第五种开放协议。

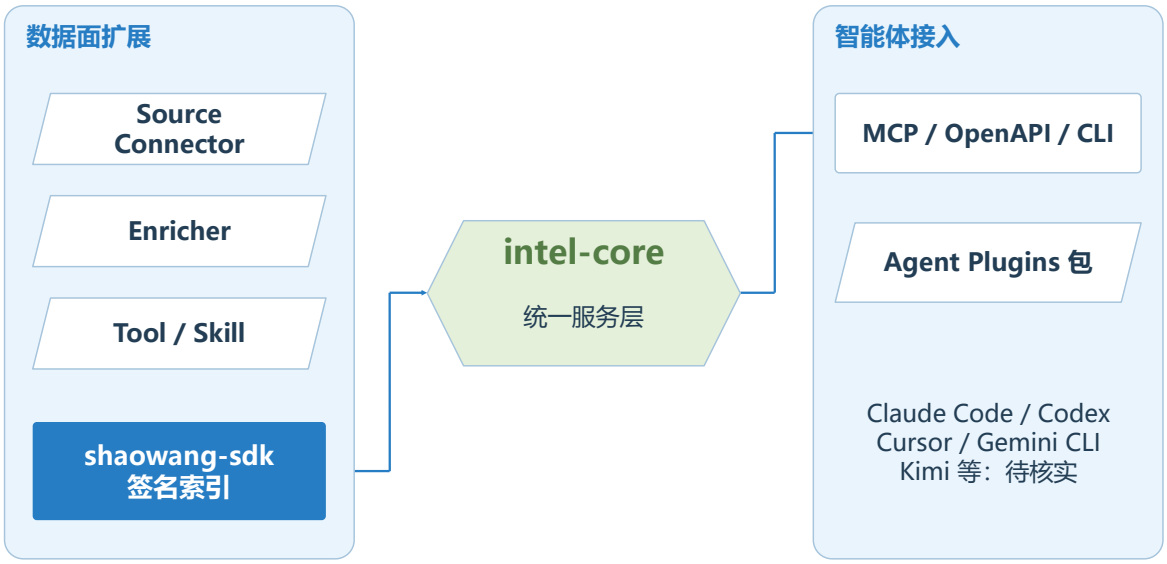


图 2.17 MCP 与插件生态全景

MCP 设计参照 2025-11-25 规范，提供 Streamable HTTP 与 stdio 两种传输。远程入口便于共享，本地入口由 shaowang mcp serve 转接 REST；两种传输暴露同一工具定义。对调用方而言，区别在连接方式，而不在某条漏洞应该得到什么结论。[37]

默认 scope 为 intel:read，可选订阅使用 alerts:write，内部采集权限不向外部工具开放。凭据通过环境或机密管理注入，只保存哈希；限流为每凭据每分钟六十次，ask 每分钟十次，超限返回 429 与 Retry-After。审计记录工具、参数摘要和耗时，不把真实凭据写入报告或日志。

客户端配置不能互相照抄。Claude Code 的 HTTP 条目、Codex 的 TOML 配置和 Cursor 的远程配置有各自格式；材料记录了官方文档核对，但还没有演示机上的兼容性实测。第三章保留调用截图位置，第四章再按客户端检查工具加载、只读行为与长任务续取。

2.7.2 七个 MCP 工具

七个工具覆盖查列表、取详情、查依赖、问答、续取任务、查看来源与可选订阅。前六个只读；subscribe_alerts 是唯一可选写入工具，只改变调用者自己的订阅，未实现时不出现在工具列表。这里描述的是七工具设计清单，不能把可选项省略后的运行列表误判为设计遗漏。

表 2.5 MCP 工具一览

工具	读写属性	用途
search_vulns	只读	按关键词、组件、严重度、KEV 等条件检索漏洞
get_vuln	只读	获取漏洞详情卡，含 9 维富化、来源列表与冲突记录
check_stack	只读	依赖清单或依赖文件自查，大清单转为异步任务
ask	只读	跨文档问答，预计超过 60 秒时返回任务句柄
get_task_result	只读	取回长任务结果，也用于获取日报和周报
list_sources	只读	列出数据源的可信度等级、健康状态和时延分位数
subscribe_alerts	写（可选，唯一非只读）	按组件或等级订阅告警，只写调用者自己的订阅

只读注解表达工具意图，服务端权限才决定实际能力。工具不能写情报、触发采集或执行任意操作。输入 Schema 的根节点使用普通对象，“二选一”等条件由服务端校验，错误显式返回；输出同时给结构化内容和简短说明，来源与引用都带等级。

ask 支持 quick 与 deep，最大跳数范围一至四、默认三；深度请求通常转异步。get_task_result 也用于读取日报和周报，保持任务结果入口统一。暴露面由漏洞详情中的富化维度提供，独立 exposure_stats 不属于当前七工具清单。

2.7.3 开放 Schema 与插件扩展

让第三方扩展来源之前，必须先说明什么样的数据可以被平台接受。八类公开 JSON Schema 包括 common、normalized-intel、vulnerability、advisory、component、enrichment、relation 和 qa-answer；采用 draft 2020-12，schema_version 为 1.2.0。统一情报结构只有一个权威定义，关系理由与引用来源不留给插件自行省略。

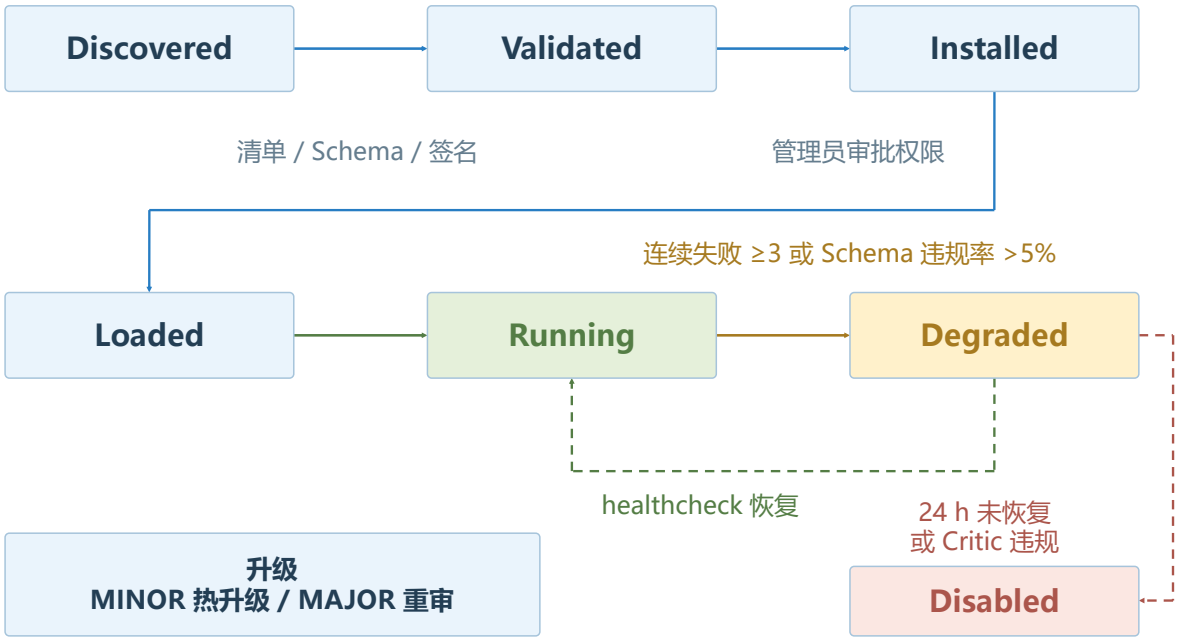


图 2.18 插件生命周期

8 类公开 Schema

common	normalized-intel	vulnerability	advisory
component	enrichment	relation	qa-answer

映射对象	OSV	STIX 2.1	CSAF 2.0
标识 / 别名	id / aliases	external_references	cve / ids
影响区间	ranges.events	software + relation	product_status
处置建议	FIX 引用	course-of-action	remediations
ATLAS	无原生项	attack-pattern	notes
关系与置信度	无原生项	relationship	无原生项
PoC 引用	EVIDENCE 链接	external_references	references

按映射表保留语义；没有原生字段的内容使用扩展，不能宣称天然无损

图 2.19 公开 Schema 与 OSV / STIX 2.1 / CSAF 2.0 的对应

三类扩展点分别接来源、补富化、组合只读工具。Source Connector 提供 poll 与 backfill；Enricher 接收只读漏洞并交出补丁和关系；Tool/Skill 组合已有查询。第三方插件没有写图权限，不能改其他插件负责的维度，输出还需经过 Schema 与合规检查。

权限默认拒绝，网络出站按声明域名限制，秘密逐项注入，私有存储不超过 10 MB。独立子进程、只读文件系统与平台代理限制插件影响范围；插件不直接连数据库，而通过上下文 RPC 访问批准能力。这样的边界让“能安装”与“能任意读取或写入”分开。

生命周期从发现、校验、安装到加载和运行。连续失败不少于三次或 Schema 违规率超过百分之五时降级；健康检查恢复后回到运行，二十四小时未恢复或被 Critic 判违规则禁用。MINOR 升级与 MAJOR 变更采用不同审批路径，避免一次接口破坏悄悄影响已安装消费者。

Schema 的 PATCH 修改描述，MINOR 增加可选项，MAJOR 删除或改变字段并升级接口。平台设计同时支持当前与上一个主版本至少六个月，并提供迁移入口。OSV、STIX 2.1、CSAF 2.0 映射用于交换，但关系置信度和 ATLAS 等内容在部分标准中没有原生字段，需要扩展保存，不能笼统宣称天然无损。[15][18][19]

远程索引携带哈希与 sigstore 签名，贡献检查覆盖权限、夹具回放、工具约定、技能元数据、安全与许可证扫描、签名及软件物料清单。富化插件需在二百条金标集回归，低于百分之九十五不授予推荐标记。这里是贡献准入要求，不是已经有插件达到门槛的统计。

2.8 关键技术选型说明

选型围绕可审计、可复现和部署复杂度展开。表中同时给出备选，避免将当前设计写成唯一可行路线；建议项仍保留建议状态，实际模型与调度器配置应在评测环境中登记。

表 2.6 关键技术选型

层次	选型	理由	备选
智能体编排	LangGraph 有状态图	节点状态持久化、检查点与回放，便于审计	AutoGen、CrewAI
消息与调度	Redis Streams 或 NATS JetStream；APScheduler / Celery Beat【建议】	演示规模最轻，原生消费组与死信	Kafka
采集	Python 插件、httpx【建议】、feedparser + trafilatura、ETag/Last-Modified	增量、幂等	requests、Scrapy

层次	选型	理由	备选
主存储	PostgreSQL 16 + pgvector	事实源与向量同库，事务一致	Milvus 2.x
知识图谱	Neo4j 5	Cypher 表达多跳直观，可视化成熟	Apache AGE
全文检索	OpenSearch 2.x + IK	BM25 稳定，中文分词成熟	Meilisearch
嵌入与重排	bge-m3、bge-reranker	中英双语，可私有化	商用嵌入 API
大模型	国产大模型 API（Qwen / DeepSeek）【建议】	中文能力好，可替换为私有化部署	本地 vLLM 部署
后端	FastAPI + pydantic v2	与 Python 栈统一，自动生成 OpenAPI	Litestar
MCP 服务	官方 Python MCP SDK	同时支持 Streamable HTTP 与 stdio	FastMCP
前端	React + TypeScript、ECharts、Cytoscape.js	图表与图谱组件丰富	Vue 3、AntV G6
可观测	Langfuse、Prometheus、Grafana	调用链追踪与时延指标统一展示	OpenTelemetry 后端
部署	docker compose	单机一键启动，便于评审复现	Kubernetes、Helm
评测	金标集 + 问答集 + 阶段时间戳；RAGAS 辅助	可复现	—

层次	报告方案	备选
采集	Python / httpx（建议）	requests / Scrapy
消息调度	Redis Streams / NATS	Kafka
编排	LangGraph	AutoGen / CrewAI
模型	Qwen / DeepSeek（建议）	私有化模型
主存储	PostgreSQL + pgvector	Milvus
图谱与检索	Neo4j / OpenSearch + IK	AGE / Meilisearch
嵌入与重排	bge-m3 / bge-reranker	商用嵌入
后端与 MCP	FastAPI / 官方 Python SDK	Litestar / FastMCP
前端	React / ECharts / Cytoscape	Vue / AntV G6
可观测	Langfuse / Prometheus / Grafana	OpenTelemetry 后端
部署	docker compose	Kubernetes / Helm

右列为备选；建议项与规划项不等于已经部署

图 2.20 技术栈分层

第一项取舍是有状态图与对话式多智能体。AutoGen 等框架适合角色对话，情报流水线却有明确的阶段和失败恢复点。LangGraph 更便于把步骤、检查点和重放路径显式表示。代价是需要提前定义状态和转移，不能依赖模型临场安排一切；对于需要审计的流水线，这种约束正是选择理由。[35][36]

第二项取舍是 pgvector 与独立向量库。事实和向量放在 PostgreSQL 中，能在演示及中等规模下减少分散运维和同步负担；Milvus 等独立服务保留为扩展选项。当前选择没有证明向量同库适合所有规模，扩容时应以实测资源和检索延迟决定迁移，而不是预先增加组件。

第三项取舍是图库与关系库并存。多跳关系用 SQL 可以表达，但路径越长，自连接与可视化组织越复杂；Cypher 直接描述路径，适合图扩展和子图展示。代价是两种存储的一致性维护，所以 PostgreSQL 仍为事实源，通过 outbox 更新 Neo4j，而不是让两边独立接受业务写入。

第四项取舍是 MCP 双传输。只提供远程 HTTP 会增加部分企业环境接入成本，只提供本地 stdio 又不利于团队共享。保留两者，同时只维护一套工具定义，可以把连接差异限制在传输层。代价是兼容性测试必须覆盖两种连接和长任务续取，不能以其中一种成功代表全部客户端通过。

第三章 作品实现

第二章确定了数据怎样流动，本章检查这些设计落实到哪里、已有证据能支持到什么程度。部署结构、存储模型与六段代码用于说明实现方案，其中代码是按设计编写的参考节选；境内连通性与 Quake 校准属于已完成的工程实测。界面截图、端到端运行和客户端兼容性仍待补齐，不以示意图替代运行证据。

3.1 系统实现细节

3.1.1 部署结构

评审复现首先需要知道哪些服务必须同时工作。当前方案采用 docker compose 单机部署，把 API、MCP、前端、工作进程和调度器分别组织为应用容器；数据库、检索、消息和对象存储则各负其责。这样的拆分让某个 worker 重启不必带动前端和事实库一起重启。



图 3.1 docker compose 单机部署结构

workers 执行九个角色，scheduler 按来源节奏派发并每十五分钟重放死信。PostgreSQL、Neo4j、OpenSearch、Redis 或 NATS、MinIO 提供数据支撑，Langfuse、Prometheus、Grafana 展示调用与指标。容器之间通过网络和消息交接，避免以共享进程内变量承载业务状态。

部署中的秘密由环境和机密管理注入，不写在代码、配置样例或测试夹具里。CI 计划用 gitleaks 扫描，证据目录也要脱敏。Kubernetes 与 Helm 属于后续扩展方向，不能把可迁移的服务边界写成已经完成集群运行或容量验证。

3.1.2 数据模型与知识图谱

多源融合最容易丢掉的不是值，而是不同来源各自说过什么。因此公告 Advisory 与漏洞 Vulnerability 分开：公告保留来源、外部编号和原始链接，漏洞保存规范身份及裁决后的字段。发现错误时，可以回到具体公告核对，不必从一个混合描述中猜测来源。

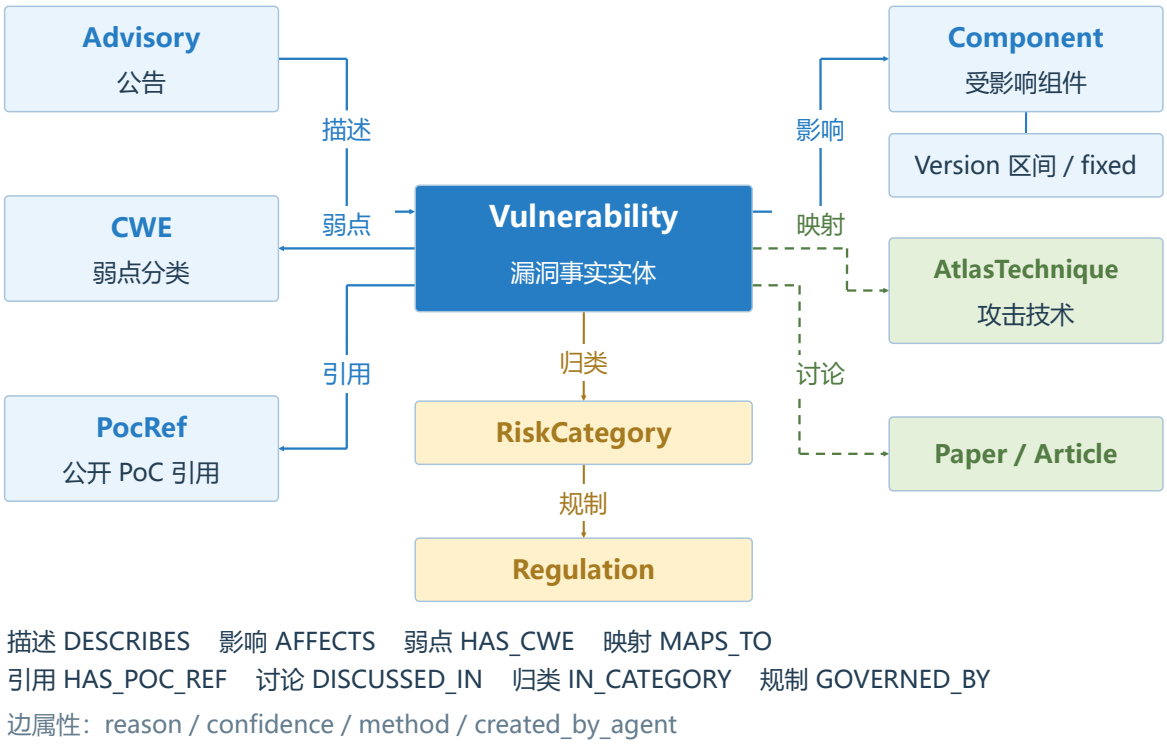


图 3.2 知识图谱数据模型

图模型包含漏洞、公告、组件、版本、CWE、ATLAS 技术、论文、文章、PoC 引用、法规和风险类别。AFFECTS 携带影响区间与修复信息，DESCRIBES 连接公告与漏洞，MAPS_TO 和 DISCUSSED_IN 支持技术与研究材料的扩展。理由、置信度、方法和创建角色与关系一起保存，使图上的路径可以落回证据。

PostgreSQL 保存归一情报、富化、任务、来源游标、冲突、审计及关系事实。pgvector 保存文本切片嵌入，OpenSearch 保存适合全文检索的标题、描述与编号；

Neo4j 保存图投影。MinIO 保留原始载荷和报告，供回放与核对。查询投影提高读取便利，但不替代事实源的有效性判断。

以近九十天 vLLM 问题为例，路径先筛选 AFFECTS，再限制发布时间和 HAS_POC_REF，最后取可选 MAPS_TO。某个漏洞没有 ATLAS 映射时，应保留“尚无映射”这一缺口，不能为了让图连通而补一条模型猜测边。图查询得到结构，引用仍需指向实际材料。

3.1.3 自愈与降级

来源短暂限流和请求参数错误需要不同处理。前者等待可能恢复，后者重复调用只会浪费配额。平台运行时统一重试策略：429、5xx 与超时优先尊重 Retry-After，否则从一秒起指数退避，设计上限五分钟并加入正负百分之二十抖动；超过六次后进入死信。

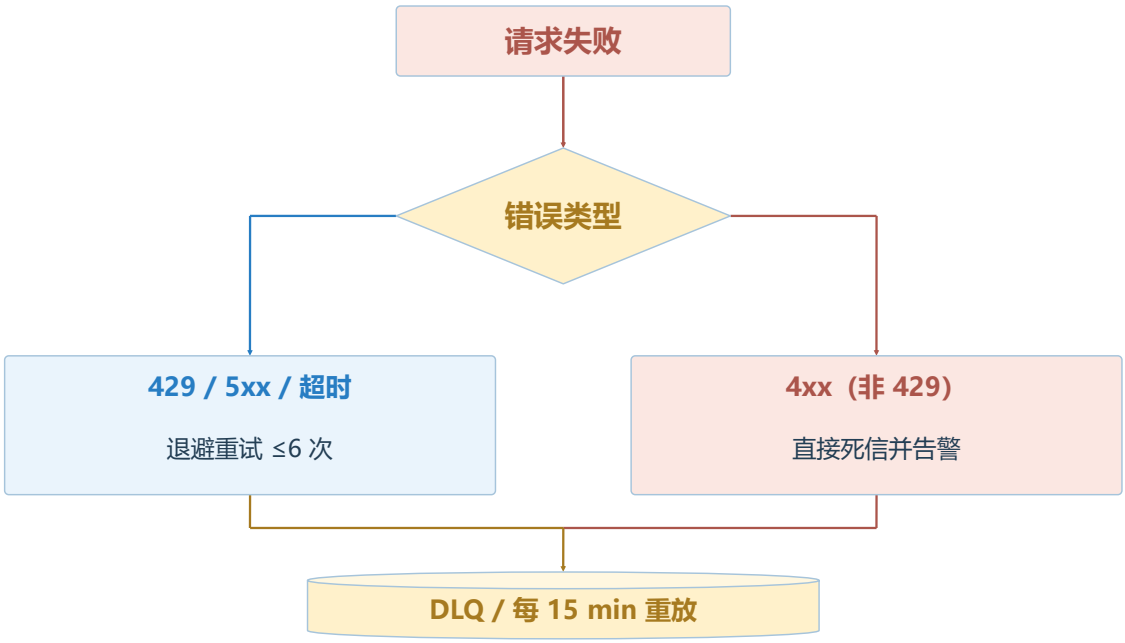


图 3.3 失败重试、死信重放与熔断降级

来源连续三个周期失败时熔断并标为 degraded，切换预设通道。NVD 可退到 cvelistV5，厂商公告可退到 Release，huntr 可从 GHSA 或 NVD 引用间接发现；EPSS 全部调用失败时保留前一天值并标 stale。降级保住部分能力，也必须公开损失的覆盖和新鲜度，不能把缓存写成刚刚查询的结果。

富化采用维度隔离，暴露面等待配额时不重跑已有 CVSS、CWE 等维度。进程崩溃后从 agent_tasks 检查点继续，恢复是否真正没有丢失任务和事实，需要故障注入验证。当前结果为**【待测：故障注入下的自愈成功率与平均恢复时间，目标值 xx】**，第四章给出六类场景，附录 F 保留逐次运行记录位置。

3.1.4 可观测性实现

仅看请求成功率无法发现情报已经过时。情报级观测用五段时间戳计算每来源 P50、P95，并通过 Prometheus、Grafana 和 list_sources 展示；任务级观测读取 agent_tasks 中的步骤、状态与耗时；调用级观测通过 Langfuse 记录提示、输出和用量。三层分别回答“情报多久可用”“卡在哪一步”“该次模型调用发生了什么”。

告警条件也围绕这三个问题设置：来源新鲜度落后三倍轮询间隔、来源 P95 超过目标、死信持续增长或插件 Schema 违规率超过百分之五，都需要暴露出来。一个接口可以持续返回成功，但抓到的仍是旧内容；因此 last_success_at 与新鲜度要结合阅读。

任务树应能跳到对应调用记录，而不需要分析师在多个日志中手工拼接。原始提示与输出还可能包含外部不可信内容，保存和展示时同样要执行秘密与资产信息过滤。可观测性不构成放宽保密边界的理由。

3.1.5 合规边界

哨望服务于防守方研判，边界贯穿输入、存储和输出。PoC 只记录引用链接与标题，暴露面只保留聚合计数，不保存目标资产清单；系统不对测绘平台返回的目标发起探测。这样，风险规模可以帮助排优先级，而不会把情报服务变成目标查询或执行入口。

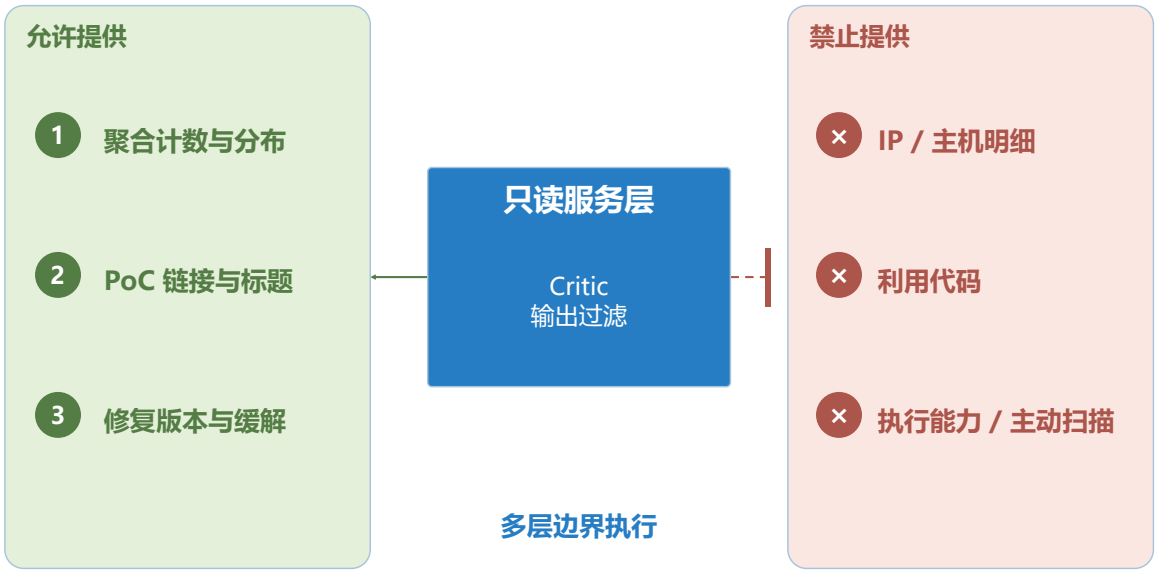


图 3.4 对外合规边界

对外工具以只读为主，不开放任意命令、写情报或触发采集能力。输出层再次检查代码块、利用载荷和资产地址，Critic 对越界问答直接判 fail。每条漏洞同时提供可核对的修复版本或缓解建议，体现防御侧信息的使用目的。[13]

第三方测绘调用不高于每秒一次，只作研究统计，不转售或重新分发原始结果。抽样校准可以读取元数据，但资产明细必须立即丢弃，不进入日志、MinIO 或模型提示。权限设计与输出过滤相互配合，单靠一句“仅供研究”不能约束实际数据流。

3.1.6 境内网络连通性验证

这是已完成的实测：2026-10-14，用户在境内网络检查了主要来源和测绘平台，结果如表所列。实测证明的是当时所测入口的响应情况，不代表已连续采集，也不代表首页背后的数据接口全部可用。原始境内终端输出尚未存档，附录 A 明确保留补证据要求。

表 3.1 境内网络连通性实测结果

来源/平台	结果	处理
NVD、GitHub、OSV、CISA KEV、FIRST EPSS、huntr、MITRE ATLAS	均 HTTP 200	所测时点支持直连方案；持续运行待验证

来源/平台	结果	处理
CNNVD	首页 200	国内主力，数据接口待确认
TC260	200	标准版本监测；具体标准文件 URL 待补
CNVD（列表、网站信息、RSS 三入口）	均 521（境内外一致）	判定反爬，降为加分项，人工/半自动导入
arXiv export API	502	改以 RSS 为主；境内 RSS 连通性待测
360 Quake 查询接口	调用成功	见 D18.2
奇安信鹰图 Hunter	境内首页 200；境外访问被拦截	API 待境内申请凭据后实测**【待测】**
FOFA	接口可达，返回 820031（积分不足）	备选，需积分后启用
ZoomEye	鉴权方式与官方文档不一致，未核实	备选，核实前不启用

第一处调整来自 CNVD。列表、网站信息和 RSS 三个入口都返回 521，材料据此判断存在反爬限制；方案改用 CNNVD 作为国内主力，CNVD 保留人工或半自动导入。CNNVD 首页 200 只支持继续调查，其具体数据接口仍待确认，不能宣称已取代 CNVD 完成自动采集。

第二处调整来自 arXiv。export API 的境内响应为 502，因此主通道改为 RSS，再保留其他补漏路径。2026-10-15 的境外 RSS 200 是补充事实，不是境内复测通过；境内 RSS 仍需补证据。这一限制在正文与附录都保留，避免环境标签在整理时丢失。

第三处调整来自 Quake。接口调用成功后，宽泛的 Ollama 指纹计数引出了口径疑问，方案增加了端口与响应特征收窄及五十条抽样门槛。该调整不是网络连通性修复，而是统计质量修正；详细数字和快照分离见 4.6.2。

3.2 核心代码说明

以下六段代码沿用旧报告节选，不改变逻辑。它们用于展示设计意图，不构成可独立运行的完整模块；类型、辅助函数、接口路径和实际仓库的一致性仍须人工核对。对节选与 dossier 之间可见的差异，本节直接说明，不用说明文字把未覆盖边界写成已经实现。

3.2.1 逐字段冲突裁决

代码 3.1 逐字段冲突裁决（enricher/resolve.py 节选）

```
SPECIAL_RULES = {"exploited": kev_only,
                 "withdrawn": tier1_withdraw_wins,
                 "affected": union_on_tier1_conflict,
                 "aliases": guard_double_cve}

def resolve_field(field: str, cands: list[Candidate]) -> Resolution:
    if field in SPECIAL_RULES:
        return SPECIAL_RULES[field](cands)
    ranked = sorted(cands, key=lambda c: (c.source_tier,
                                          -c.provenance.confidence,
                                          -c.source_modified_at.timestamp()))
    winner, losers = ranked[0], ranked[1:]
    conflicts = [Conflict(field=field, value=l.value, source=l.source,
                          winner_source=winner.source,
                          rule=_decisive_rule(winner, l))
                 for l in losers if l.value != winner.value]
    only_t3 = all(c.source_tier == 3 for c in cands)
    status = "unconfirmed" if only_t3 else "confirmed"
    return Resolution(value=winner.value, provenance=winner.provenance,
                      conflicts=conflicts, status=status)
```

三元组排序键把“等级优先、置信度其次、更新时间最后”的顺序摆在同一处。前一级已经分出胜负，就不会再让后一级推翻结果。特殊字段另行注册，避免 KEV 权限、撤回或区间冲突被普通排序覆盖；这种集中写法也便于审查有哪些例外。

落选值被写入冲突记录，主值因此不是一次不可解释的覆盖。仅三级来源支撑时标记 unconfirmed，与高危告警限制衔接。节选没有展示空候选校验和所有特例函数，完整实现仍需验证这些边界；例如两个一级 CVSS 值谁胜出，要看真实时间与候选信息，不能在代码说明中预设高分获胜。

3.2.2 版本区间求解

代码 3.2 OSV 版本区间求解（check/ranges.py 节选）

```
def is_affected(version: str, ranges: list[Range], eco: str) -> Verdict:
    v = parse_version(version, eco)
    hits = []
    for r in ranges:
        events = sorted(r.events, key=lambda e: parse_version(e.version, eco))
        affected = False
        for e in events:
            ev = parse_version(e.version, eco)
            if e.kind == "introduced" and v >= ev: affected = True
            elif e.kind == "fixed" and v >= ev: affected = False
            elif e.kind == "last_affected" and v > ev: affected = False
            elif e.kind == "limit" and v >= ev: affected = False; break
        hits.append(affected)
    if not hits:
        return Verdict.UNKNOWN
    if any(hits) and any(r.conflict for r in ranges):
        return Verdict.VULNERABLE_WITH_CONFLICT
    return Verdict.VULNERABLE if any(hits) else Verdict.CLEAN
```

状态扫描表达了版本区间的开闭语义：fixed 与 last_affected 的边界不同，limit 又代表停止检查的上界。将版本解析交给生态函数，避免直接按字符串比较。命中且存在来源冲突时返回单独结果，可以把“保守判断为受影响”与“各方一致确认”区分开。

这段参考代码省略了生态解析与输入验证。OSV 的特殊事件值、事件排序、无法解析的版本和缺少区间时的含义，必须由完整实现和回归覆盖，不能仅据这段循环宣称全部语义已验证。内部 CLEAN 也应在界面译为“未发现已知影响”，不能扩大为没有任何安全风险。

3.2.3 混合检索的倒数排名融合

代码 3.3 三路检索结果的 RRF 融合（qa/retrieve.py 节选）

```
RRF_K = 60

def hybrid_retrieve(q: Query, top_k: int = 12) -> list[Chunk]:
    lists = {"bm25": bm25_search(q.text, size=50),
             "vector": vector_search(embed(q.text), size=50),
             "graph": graph_expand(link_entities(q), hops=q.hops or 2)}
    scores, chunks = defaultdict(float), {}
    for name, results in lists.items():
        for rank, ch in enumerate(results, start=1):
            scores[ch.id] += 1.0 / (RRF_K + rank)
            chunks[ch.id] = ch
    fused = sorted(chunks.values(), key=lambda c: -scores[c.id])[:50]
    reranked = rerank(q.text, fused)
    return reranked[:max(8, min(top_k, 12))]
```

RRF 不直接混加 BM25、向量和图扩展的原始分数，而把各路排名变成可加的倒数项。常数六十缓和头部名次差异，同一证据块在多路出现会累计分数；统一块标识同时承担去重职责。[31]

融合只是候选组织，不能替代证据质量判断。前五十项交给重排器，最后截取八至十二个块；如果实际召回不足，切片不会凭空补出八个证据。多跳是否找回必要中间材料、图扩展是否引入噪声，要通过第四章的同条件对照回答。

3.2.4 Critic 引用校验

代码 3.4 答案引用的逐句校验（agents/critic.py 节选）

```
def check_citations(answer: QAAnswer, corpus: DocStore) -> CriticVerdict:
    unsupported, sentences = [], split_sentences(answer.answer)
    for s in sentences:
        refs = extract_refs(s)
        if not refs:
            unsupported.append(s); continue
        evid = [corpus.get(answer.citation(n).doc_id) for n in refs]
        if any(e is None for e in evid):
            return CriticVerdict("fail", reason="citation_not_in_corpus")
        if max(entailment(e.snippet, s) for e in evid) < ENTAIL_THRESHOLD:
            unsupported.append(s)
    if contains_exploit_code(answer.answer) or contains_ip(answer.answer):
        return CriticVerdict("fail", reason="policy_violation")
    ratio = len(unsupported) / max(1, len(sentences))
    if not unsupported: verdict = "pass"
    else: verdict = "partial" if ratio <= 0.3 else "fail"
    return CriticVerdict(verdict, unsupported_claims=unsupported)
```

存在性检查先于蕴含判断。引用指向不存在文档时直接失败，防止生成器以伪造编号制造可信感；没有引用或证据不支持的句子加入 unsupported_claims。合规检查独立执行，即使某句话有原文依据，也不能把利用代码或资产地址返回给调用者。

partial 保留了有限不确定性：不受支持句子占比不超过百分之三十时明确列出，超过则失败。这里的蕴含阈值、断句和引用解析由辅助实现承担，节选未给出它们的准确率。Critic 的作用需同时考察正确拦截与误拦，不能把“通过检查”当作绝对正确的证明。

3.2.5 带抖动的指数退避与死信

代码 3.5 连接器调用的退避重试（runtime/retry.py 节选）

```
RETRYABLE, MAX_ATTEMPTS, CAP_SEC = {429, 500, 502, 503, 504}, 6, 300

async def run_with_retry(task: Task, call: PollCall) -> PollResult:
    for attempt in range(MAX_ATTEMPTS):
        try:
            return await call()
        except HttpError as e:
            if e.status not in RETRYABLE:
                await dlq.put(task, reason=f"http_{e.status}")
                alert(task, e); raise
            wait = e.retry_after or min(CAP_SEC, 2 ** attempt)
        except TimeoutError:
            wait = min(CAP_SEC, 2 ** attempt)
        await asyncio.sleep(wait * random.uniform(0.8, 1.2))
    await dlq.put(task, reason="max_attempts")
    if await health.record_failure(task.source) >= 3:
        await health.mark_degraded(task.source)
    raise RetryExhausted(task)
```

将重试放到运行时，使连接器共享等待、死信与健康状态语义。插件遇限流时交出 Retry-After，平台负责后续调度；不可重试错误立即告警，避免重复占用来源配额。随机抖动则分散任务的再次请求时刻。

节选只枚举了部分 5xx，且将随机系数也乘到 Retry-After 上；上限是在抖动之前应用的。它不能完整证明“所有 5xx”“严格遵守服务端最小等待”或“最终等待不超过五分钟”。MAX_ATTEMPTS 的尝试次数与 dossier 的重试次数表述也需要对齐。本次保留代码逻辑，将差异列入交付说明，实际实现须按合同核查后再用于运行验收。

3.2.6 长任务句柄

代码 3.6 ask 工具的同步与异步分流（mcp/tools/ask.py 节选）

```
SYNC_LIMIT_SEC, MAX_TOKENS = 60, 8000

@tool(name="ask", read_only=True)
async def ask(ctx: ToolContext, question: str, mode: str = "standard"):
    eta = estimate_eta(question, mode, queue_depth=ctx.queue.depth("qa"))
    orch = ctx.orchestrator
    if eta > SYNC_LIMIT_SEC:
        task = await orch.submit("qa", question=question, mode=mode,
                                 caller=ctx.key_id)
        handle = TaskHandle(task_id=task.id, status=task.status,
                            poll_with="get_task_result", eta_sec=eta)
        return ToolResult.of(task=handle)
    answer = await orch.run_inline("qa", question=question, mode=mode)
    return ToolResult.of(answer).fit(max_tokens=MAX_TOKENS)
```

分流发生在执行前，而不是等待超时后。这样可以直接给客户端一个可续取的任务身份，减少重复执行风险；poll_with 明确下一步调用 get_task_result。同步结果经 fit 控制长度，异步结果也应遵循同样的过滤、鉴权和分页约定。

代码中的默认模式 standard 与 dossier 规定的 quick / deep 不一致，且节选没有展示异步续取端的结果过滤。它说明了任务句柄的设计思路，尚不足以证明全部接口契约已经实现。本报告保留原节选、不静默改逻辑，并将模式与路径一致性留作仓库核对项。

3.3 各功能模块实现效果展示

本节按分析师和开发者的使用顺序组织九处截图。下列页面说明是展示目标，灰色框仅占位，不是运行截图；DEMO 条目必须显式标记。真实截图补齐后，需要与正文里的任务、来源和时间记录对应，才可作为实现效果证据。

3.3.1 监测 态势大屏

分析师进入大屏后，需要先判断情报是否新鲜、哪些来源退化，再看新增风险。拟展示的关键指标卡、来源状态灯、实时流和时延分布应围绕这一顺序组织。CNVD 人工导入与自动轮询要可区分，六小时线只解释对应统计范围，不能把所有日更资料都算作超时。



图 3.5 态势大屏

【截图待补 S-01：态势大屏全屏截图，需包含 KPI 卡、9 个数据源状态灯（其中 CNVD 显示为人工导入）、实时情报流中一条无 CVE 的厂商公告、时延分布图的 6 h 阈值线】

真实截图还需包含 ATLAS 热力图与仅计数的暴露面趋势。

3.3.2 富化 情报详情卡与关联图谱

详情卡应把主值与分歧放在同一阅读路径。用户看见评分之后，能继续检查各来源的向量、裁决规则和九维完成状态；暴露面只显示计数。这样既可快速研判，也不会因首页只显示一个分数而隐藏来源冲突。



图 3.6 情报详情卡

【截图待补 S-02：以 CVE-2025-32444 或演示公告为例的详情卡，需展示 GHSA 与 NVD 两个 CVSS 取值的冲突记录、9 维富化逐项点亮后的状态、暴露面维度“仅计数”的提示】

来源须显示 tier 徽章。

图谱视图负责解释关系，而不只是增加节点。规则边、模型边与候选边用线型区分，点击边可查看理由、置信度与证据；示例子图需同时出现影响、ATLAS 与论文关系。没有真实截图前，不把节点数量或布局表现写成已经观察到的效果。



图 3.7 知识图谱视图

【截图待补 S-03：以新漏洞为中心的 2 跳子图，需同时出现 AFFECTS、MAPS_TO、DISCUSSED_IN 三类边，并在右侧面板展开一条 LLM 边的理由与置信度】

线型区分规则、LLM 和待审候选。

3.3.3 问答 带引用的推理侧栏

问答侧栏应允许用户逐步核对问题是怎样拆解的。四步检索计划、各步命中和逐句引用在同一界面展开；partial 不能仅用绿色通过标记替代，未支持句子要保持可见。深度请求超过同步窗口时，页面展示任务身份与续取状态。



图 3.8 问答侧栏与推理步骤

【截图待补 S-04：多跳问题“近 90 天影响 vLLM 且已有 PoC 链接的漏洞有哪些，对应 ATLAS 技术”的完整问答，需展开 4 步推理链与引用片段，Critic 结论为通过或部分通过】

3.3.4 自查 版本自查页面与命令行

上传依赖文件后，用户需要区分明确受影响、已有知识未命中与未收录组件。三类结果同时出现，才能证明界面没有把未知写成安全；修复建议与来源分歧也应与组件同行展示。命令行示例用于说明同一能力如何进入开发流程。



图 3.9 版本自查页面

【截图待补 S-05：上传含 vllm 与 ollama 旧版本的 requirements 示例文件后的结果页，需包含“受影响”“未发现已知影响”“组件未收录”三种状态各至少一行】

底部保留等价 CLI。

3.3.5 编排 智能体任务树

任务树的作用是解释等待与失败。一次演示注入应能展开富化维度、Critic 驳回与重写、配额等待和最终状态；触发来源明确标记为演示。只有展示真实执行节点，才能检验角色之间的状态交接是否与设计一致。



图 3.10 智能体任务树

【截图待补 S-06：一次演示注入触发的完整运行，需包含 Critic 驳回一次后重写通过的节点、暴露面维度“等待配额”状态，以及触发来源标签】

3.3.6 开放 插件状态与编码智能体调用

插件状态页需要回答哪些能力已加载、有什么权限、哪里出现降级。MCP 列表按七工具设计展示六个只读和一个可选写入，实际未实现订阅时不应伪造已加载状态。插件版本、沙箱和健康信息用于支撑扩展的可审计性。



图 3.11 插件与 MCP 状态页面

【截图待补 S-07：MCP 工具标签页与接入客户端标签页各一张，需显示 7 个工具中 6 个只读、1 个可选写入的标记】

编码智能体对话应保留工具选择、结构化结果与带来源的回答。只读标注是否产生预期审批行为，要以当时客户端策略为准；配置中的凭据打码。文档核对只证明配置有依据，不能替代这段真实调用。



图 3.12 Claude Code 通过 MCP 调用 check_stack

【截图待补 S-08：Claude Code 中的完整对话截图，需显示工具调用确认（只读工具无需确认）、返回的结构化结果和带链接的回答；配置中的凭据需打码】

持续集成日志应展示检查命令、返回结果和非零退出码，让评审判断门禁究竟因何失败。退出码来自依赖风险判断，而不是脚本异常或网络错误；后两种情况需要独立说明，不能冒充成功拦截漏洞。



图 3.13 命令行工具在持续集成中的使用

【截图待补 S-09：终端或 CI 日志截图，显示 shaowang check -f requirements.txt --min-severity high 的输出与非零退出码】

第四章 测试与分析

当前能够报告的实测是来源入口连通性和 Quake 的 Ollama 计数校准。监测时效、富化准确率、问答质量、故障自愈与编码智能体兼容性尚待测量。本章先冻结样本、指标和对照方式，再保留结果位置；只有这样，后续回填的数字才能回答设计是否成立，而不是仅仅展示一个看起来不错的总分。

4.1 测试方案与环境

测试分项报告时效、覆盖、准确性和可靠性。每项结果要能追到数据集、配置和原始记录；问答采用三组对照，Critic 同时统计校验前后质量。总体数字可以作为摘要，但不能掩盖某来源长期失效、某类关系误判或多跳题表现不足。

表 4.1 测试环境

项目	配置
部署方式	计划采用 docker compose 单机部署
硬件	**【待测：测试机 CPU、内存、磁盘配置，目标值 按实际填写】**
网络	计划境内直连；记录实际运行网络
大模型与嵌入	建议国产大模型 API；bge-m3 与 bge-reranker；实际版本待登记
数据规模	**【待测：测试时库内漏洞、公告、关系边数量，目标值 按实际填写】**
测试周期	**【待测：连续运行观测天数，目标值 ≥7 天】**

表中部署、模型和网络项描述计划环境，硬件、实际数据规模与连续运行时长仍需填写。某天入口返回 200，不等于完成不少于七天的连续观测；使用 fixture 通过功能测试，也不能填入真实模型或来源的质量指标。附录 E 预留环境与原始时延记录，附录 G 保存评测运行信息。

表 4.2 测试指标与设计目标

测试类别	指标	设计目标	实测结果
监测时效	漏洞类情报端到端时延 P95	≤6 h	**【待测：端到端时延 P95，目标值 ≤6 h】**
监测时效	P0 厂商公告采集时延 P95	≤10 min	**【待测：P0 厂商公告采集时延 P95，目标值 ≤10 min】**
监测覆盖	实际接入的来源类别数	≥7 类	**【待测：已实现并稳定运行的来源类别数，目标值 ≥7】**

测试类别	指标	设计目标	实测结果
富化准确	200 条金标集富化与关联准确率	≥95%	【待测：富化与关联准确率，目标值 ≥95%】
问答质量	100 题答案准确率	xx%	【待测：答案准确率，目标值 xx%】
问答质量	100 题引用正确率	xx%	【待测：引用正确率，目标值 xx%】
编排可靠	故障注入下的自愈成功率	xx%	【待测：自愈成功率，目标值 xx%】
接口性能	只读 MCP 工具同步调用时延 P95	xx s	【待测：MCP 只读工具时延 P95，目标值 xx s】



图 4.1 评测体系总览

监测 P95 不超过六小时、P0 采集 P95 不超过十分钟、稳定来源不少于七类、二百条金标集准确率不低于百分之九十五，均为设计目标。问答、自愈和接口性能中的 xx 是待冻结目标，不是零值或已达标状态。未定门槛需要在正式比较前补全，不能看到结果之后再调整目标。

4.2 监测时效测试

4.2.1 测试方法

五段时间戳把发现与处理分开。端到端时延以 queryable_at 减 source_published_at，采集时延以 first_seen_at 减 source_published_at，处理时延以 queryable_at 减 first_seen_at。单次 HTTP 耗时只覆盖一个请求，不能替代任何一个完整阶段的时延。

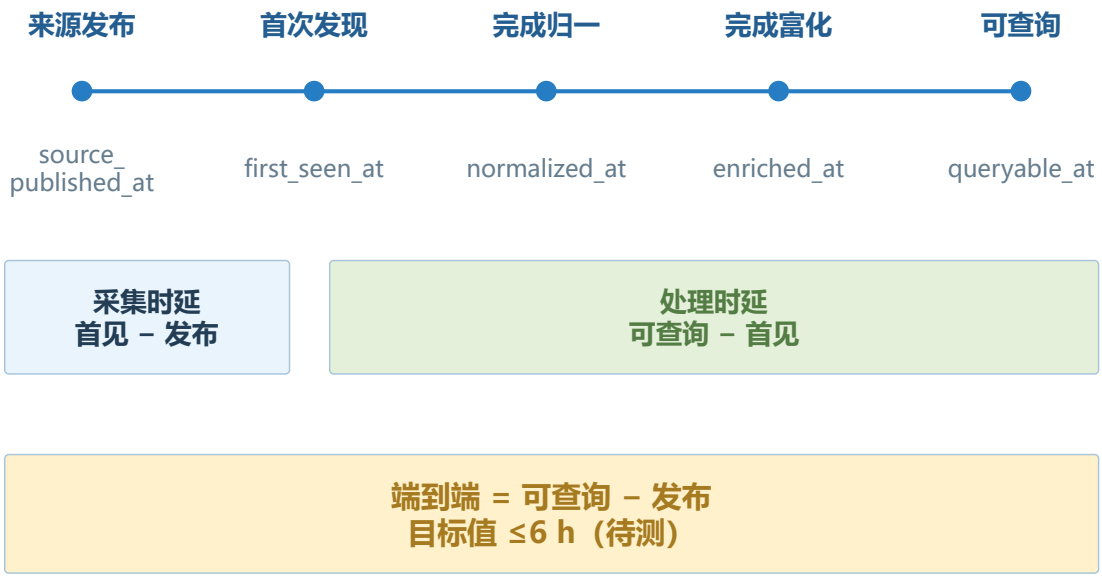


图 4.2 时效统计的时间戳定义

统计对象限定为漏洞类首次发现，来源为 NVD、GHSA、OSV、厂商公告和 huntr。DEMO 排除，日更来源单列。仅精确到日的发布时间按当天零点计算，可能保守高估时延；记录中保留时间精度，使不同来源的分位数能被正确解释。

连续观测目标不少于七天，实际不足时如实报告天数。重试、降级和配额等待都属于系统实际运行条件，不能只挑选顺利处理的样本。来源更新时间与首次发布时间分开保存，防止一条旧漏洞补评分时被当作新发布样本。

4.2.2 测试结果

各来源采集阶段与漏洞类合计端到端结果分别占行。表中目标用于对照，不是已有测量；P50 与 P95 等待真实时间记录计算。

表 4.3 各来源时延统计

来源	轮询间隔	目标 P95	实测 P50	实测 P95
厂商 GitHub 公告（P0）	5 min	≤10 min	**【待测：P50】**	**【待测：P95，目标值 ≤10 min】**
GHSA	10 min	≤15 min	**【待测：P50】**	**【待测：P95，目标值 ≤15 min】**
NVD	10 min	≤30 min	**【待测：P50】**	**【待测：P95，目标值 ≤30 min】**
OSV	15 min	≤30 min	**【待测：P50】**	**【待测：P95，目标值 ≤30 min】**
huntr	1 h	≤2 h	**【待测：P50】**	**【待测：P95，目标值 ≤2 h】**
漏洞类合计（端到端）	—	≤6 h	**【待测：P50】**	**【待测：P95，目标值 ≤6 h】**

【图待补：各来源时延分布箱线图，含 6 h 阈值线】

图 4.3 各来源时延分布箱线图

从设计上可以预期，轮询间隔影响发现阶段，模型与测绘配额影响处理阶段，但当前没有证据说明哪一段已经成为瓶颈。NVD 后续评分补全与漏洞首次发现也需分开：主值完整度可能继续变化，首次可查询的时点却不能因此反复重置。

箱线图要和表使用同一批样本及排除规则，六小时线对应端到端统计。来源没有足够观测时，应保留缺失解释，不能以零时延绘图。待原始记录补齐后，再分析长尾是否来自来源发布时间精度、重试、模型等待或写入阶段。

4.3 富化与关联准确率测试

4.3.1 金标集构建

计划使用二百条金标，覆盖多源合并、ATLAS 映射与版本区间三类判断。样本加入无 CVE 公告、双 CVE 别名、CVSS 分歧和不规范版本号，避免只测容易的规则直连关系。两人独立标注，分歧由第三人仲裁；一致性为**【待测：金标集双人标注一致性 Cohen's κ，目标值 ≥0.8】**。

标注不仅给结论，还要保留支撑材料，尤其说明候选为何不能合并、某版本为何位于边界。否则模型输出与参考答案一致时，仍无法判断它是否依据正确证据。金标集当前是评测计划，不能把二百这一规模写成已经完成标注的数量。

4.3.2 评测协议与结果

多源合并用精确率与召回率，版本判断看区间一致率，ATLAS 看 Top-1 准确率。三类任务的错误含义不同，所以先按类型给出混淆结果，再报告总体，不用大量容易的规则样本掩盖弱关联误差。

表 4.4 富化与关联准确率评测

关联类型	生成方法	样本数	评价指标	实测结果
多源合并	规则（别名并查集）与候选复核	**【待测：样本数】**	精确率、召回率	**【待测：多源合并精确率与召回率，目标值 ≥95%】**
受影响版本区间	规则（OSV 区间解析）	**【待测：样本数】**	区间完全一致率	**【待测：版本区间一致率，目标值 ≥95%】**
ATLAS 映射	关键词规则与大模型，Critic 校验	**【待测：样本数】**	Top-1 准确率	**【待测：ATLAS 映射 Top-1 准确率，目标值 xx%】**
总体	—	200	准确率	**【待测：总体富化与关联准确率，目标值 ≥95%】**

Critic 的价值需要在同一批模型关联上比较校验前后准确率：**【待测：Critic 校验前后 ATLAS 映射准确率对比，目标值 校验后提升】**。同时报告**【待测：Critic 误拦率，目标值 xx%】**，因为提高门槛可能拦住错误，也可能丢掉有依据的关系。只看通过样本中的准确率，不能说明整体可用性提高。

错误分析应回到来源、合并、区间解析、模型关联与校验环节，区分知识缺失和推理错误。若金标本身存在争议，需要保留仲裁记录，不能为让某个实现通过而修改难例。附录 G 预留错例和运行版本，方便回填后复算。

4.4 问答质量测试

4.4.1 评测集与基线

约一百题覆盖单文档事实、跨文档检索、多跳推理和深度分析，每题给出参考答案与支撑证据。事实题检查编号、评分与版本，多跳题检查组件、时间、公开链接和技术映射的组合约束。题型分开统计，才能知道图扩展帮助的是哪类问题。

三组配置为向量检索 RAG、BM25 与向量融合、三路检索加 Critic。模型和生成提示保持相同，只改变检索与校验。第三组同时引入图扩展和 Critic，因此整体差异首先说明组合方案效果；若要分别归因，还应结合已有的 Critic 前后分析，不能从三组总分直接推出每个组件的独立贡献。

4.4.2 评价指标与结果

答案准确率由人工对照参考答案判断；引用正确率看引用是否支持所在句，引用覆盖率看结论句是否有证据支撑。RAGAS 忠实度作为辅助指标，不能替代人工对版本边界与风险结论的判定。[32]

表 4.5 问答质量评测结果（三组对照）

配置	答案准确率	引用正确率	多跳题准确率
向量检索 RAG	【待测：答案准确率】	【待测：引用正确率】	【待测：多跳题准确率】
BM25 + 向量	【待测：答案准确率】	【待测：引用正确率】	【待测：多跳题准确率】
三路检索 + Critic（本系统）	【待测：答案准确率，目标值 xx%】	【待测：引用正确率，目标值 xx%】	【待测：多跳题准确率，目标值 xx%】

目前表中未填任何质量结果，也没有把模板回答计为多跳推理。回填时应同时查看错误答案是否带有看似正确的引用、partial 是否清楚标注、资料缺失时是否承认不知道。多跳命中数增加并不必然提高答案质量，新增证据是否相关需要通过这些指标检验。

4.5 编排可靠性与故障注入测试

可靠性测试关注故障之后的任务和事实是否恢复，而不是只看进程能否重新启动。六类场景覆盖限流、短时服务端错误、连续周期故障、参数错误、单维超时和 worker 终止，分别对应等待、死信、熔断、拒绝重试、隔离与检查点恢复。

表 4.6 故障注入测试场景

故障场景	注入方式	预期行为	实测结果
数据源限流	模拟返回 429 与 Retry-After	按 Retry-After 等待后重试成功	**【待测：限流场景恢复情况】**
数据源临时故障	模拟连续返回 503	指数退避，6 次后进入死信队列，15 分钟后重放成功	**【待测：死信重放成功率】**
数据源长时间不可用	连续 3 个周期返回 5xx	熔断并标记 degraded，切换降级通道	**【待测：熔断与降级切换时间】**
请求参数错误	模拟返回 400	不重试，直接进入死信队列并告警	**【待测：告警是否触发】**
富化维度失败	让暴露面查询超时	只重试该维度，其他 8 维正常完成	**【待测：维度级隔离是否生效】**
智能体进程崩溃	强制终止 workers 容器	重启后从检查点恢复，任务不丢失	**【待测：检查点恢复成功率】**

每次注入要记录触发、发现、降级、故障消除和恢复的时间，并确认没有丢失任务或重复形成事实。自愈成功率按故障消除后在设定时间内恢复且无数据丢失的场景计算，平均恢复时间从故障消除算起。结果为**【待测：自愈成功率与平均恢复时间，目标值 xx】**，恢复时限仍需在运行协议中冻结。

参数错误是一个容易混淆的场景。400 不应被反复重试，进入死信并告警才是预期行为；该场景不能因为没有自动重放成功就被误判为系统失败，也不能因告警出现就宣称业务数据已经恢复。每个场景应按各自可观察行为验收。

4.6 编码智能体兼容性与已完成的工程验证

4.6.1 编码智能体兼容性

2026-10-14 已核对 Claude Code、Codex、Cursor 的官方 MCP 配置文档，尚未在演示机完成下表运行。工具能够被发现、只读策略符合预期和长任务能够续取，是三项独立检查；配置文件语法正确只能支持开始测试，不能替代其中任何一项。

表 4.7 编码智能体兼容性测试

客户端	接入方式	工具加载	只读免确认	长任务续取
Claude Code	远程 MCP 与本地 stdio	【待测：工具加载】	【待测：只读免确认】	【待测：长任务续取】
Codex	远程 MCP 与本地 stdio	【待测：工具加载】	【待测：只读免确认】	【待测：长任务续取】
Cursor	远程 MCP	【待测：工具加载】	【待测：只读免确认】	【待测：长任务续取】
Gemini CLI	本地 stdio 扩展	【待测：工具加载】	【待测：只读免确认】	【待测：长任务续取】

Codex 的远程与 stdio 路径分别保留结果，Cursor 验证远程，Gemini CLI 验证 stdio 扩展。只读免确认受客户端策略影响，应记录实际设置。附录 D 与截图 S-08、S-09 分别承接调用实录和界面证据，避免在不同章节给出互相矛盾的完成状态。

4.6.2 已完成的工程验证

境内连通性与测绘校准已经产生具体观察，但两者回答的问题不同。2026-10-14，NVD、GitHub、OSV、CISA KEV、FIRST EPSS、huntr 和 MITRE ATLAS 在所测境内环境均返回 HTTP 200，支持当时采用直连方案；它不保证之后持续可用，更不构成六小时时效已达标的证据。

CNVD 三入口 521 与 arXiv export API 502 推动了通道调整。CNNVD 首页 200、Hunter 境内首页 200 都不能证明业务 API 完成；FOFA 返回 820031 表明接口可达但积分不足，ZoomEye 鉴权方式未核实。2026-10-15 15:57 境外观测的 arXiv RSS 200、Semantic Scholar bulk 429、avid-db 200 和 Hunter 首页 403 必须保留境外标签。

表 4.8 暴露面查询语法校准记录（Quake，Ollama）

时间（北京）	语法	结果	说明
2026-10-14	app:"Ollama"	约 82 万	首次实测，判定过宽
2026-10-15 15:57	app:"Ollama"（宽口径）	823 690	只作上限参考，不展示
2026-10-15 15:57	port:11434 AND response:"Ollama is running"（收窄）	172 411（约 17.2 万）	全球
2026-10-15 15:57	收窄 + country:"China"	51 612（约 5.2 万）	国内（以平台国家字段为准）
2026-10-15 19:55	收窄语法 50 条元数据抽样	44/50 命中，精确率 88%	≥80% 门槛，状态 verified（抽样时平台返回总数为 172 401）



图 4.4 暴露面计数的语法校准

Quake 的第一次 Ollama 查询采用宽泛应用指纹，2026-10-14 返回约八十二万条。第二天 15:57 相同宽口径为 823 690。Cisco Talos 的 Shodan 案例记录 1 139 个暴露 Ollama 服务、其中 214 个无需认证；平台、时间与定义不同，不能将两组数字直接相减或计算平台准确率，但差异提示宽指纹需要校准。[40]

收窄后的条件是默认端口 11434 且响应包含“Ollama is running”。2026-10-15 15:57，全球计数为 172 411，增加中国国家字段限制后为 51 612。宽口径只作上限参考，不用于主展示；收窄计数描述的是匹配这一语法的服务，不能直接称为某个漏洞的受影响资产数。

同日 19:55，对收窄语法做五十条元数据抽样，四十四条符合特征，精确率 88%，达到百分之八十的上线门槛，状态为 verified。抽样当时总数为 172 401，与 15:57 的 172 411 不同，两者按快照分别保存。抽样判断只使用标题、端口与响应特征，没有主动验证目标漏洞，也没有形成可对外分发的资产清单。

这项结果支持 Ollama 当前查询语法通过既定校准门槛，不支持其他九个组件自动通过。Hunter 尚为**【待测：鹰图 Hunter 境内接口可用性与计数口径】**，FOFA 与 ZoomEye 也不能拿 Quake 的验证替代。材料记录了暴露面证据目录及脱敏扫描结果；本次附件未提供原始目录，因此本文引用的是 dossier 中的实测记录，未重新复算原始响应。

4.7 对比分析

在定量结果缺失时，只能比较设计范围和证据组织方式。下表把通用漏洞资料、开源情报平台和普通检索问答作为典型路线，不能据此断言每个具体产品都缺少某项能力，也不将哨望的设计目标冒充已经测出的优势。

表 4.9 与相关方案的定性对比

对比项	通用漏洞资料	情报平台路线	普通 RAG 路线	哨望设计
无编号公告	依来源覆盖	依连接器适配	依语料范围	P0 五分钟轮询与内部标识
时效观测	来源时间字段	依部署观测	依实现观测	五段时间戳，P50/P95
冲突裁决	保留各源主张	依研判流程	依生成判断	字段规则与冲突留痕
关联解释	来源引用	图关系组织	文本关联	边带理由、方法与置信度
多跳问答	提供事实材料	需结合检索生成	需多步检索机制	显式计划与引用校验
故障恢复	外部来源条件	依部署与扩展	依运行平台	退避、死信、熔断、降级
编码智能体	API 等方式	依集成方式	依实现方式	七工具设计与插件包

哨望把无编号公告、字段冲突、版本自查、可解释关联和编码智能体入口放在同一流程中，代价是来源维护、模型校验和多存储一致性工作增加，覆盖范围也限定于 AI 基础设施。收益须在相同样本、模型和提示下评测；已有证据支持通道调整与 Quake 计数语法校准，其余准确率、引用质量和恢复效果仍待验证。

第五章 创新性说明

本章讨论七项设计区别，以及判断它们是否成立需要什么证据。创新点不是把现成组件列在一起，而是让来源发现、关系证据、版本判断和开发流程形成可检查的衔接。图中归纳设计关系；除已列明的工程实测外，效果仍以第四章评测为准。

创新方向	关键机制	验证维度
1 面向 AI 基础设施的垂直多源融合	P0 5 min / 无 CVE 入库	监测 / 时效
2 可解释的自动关联推理引擎	边带理由 / Critic 门槛	富化 / 准确
3 从依赖文件出发的影响自查	OSV 求解 / 三种结果	富化 / Agent
4 可解释 GraphRAG 问答	三路检索 / 逐句引用	问答 / 准确
5 内部多智能体编排与外部 MCP 开放	9 角色 / 统一服务层	Agent
6 时效可观测与故障自愈	五段时间戳 / 故障恢复	时效 / 自动化
7 开放的插件生态	8 Schema / 三类扩展点	Agent / 文档

七项创新均需第四章评测验证；当前未测结果保持占位

图 5.1 七项创新点总览

5.1 面向 AI 基础设施的垂直多源融合

以外部漏洞编号作为唯一入口，容易错过尚未分配编号的厂商修复信息；仅增加博客和论文，又会引入未经确认的说法。哨望把厂商公告与 Release 弱信号直接纳入，用内部 SW 编号承接无编号材料，再以明确别名逐步合并到规范身份。发现的时间不必等待权威库补齐评分。

设计区别在于覆盖与可信同时处理。九类来源扩展线索，三级来源等级限制结论采用，逐字段裁决保留分歧；新材料不必被迫在“完全忽略”和“全部相信”之间二选一。第二章 2.4、2.5 给出了这套机制，第四章 4.2、4.3 将分别检验它的时效和合并准确性。

境内探测已经推动 CNVD 主次关系调整，但尚不能证明九类来源稳定运行。稳定来源不少于七类仍是待测目标。垂直融合的价值需要真实连续记录支撑，不能用设计清单中的九类直接填入覆盖成绩。

5.2 可解释的自动关联推理引擎

自动生成一条关系很容易，事后解释它为什么存在更难。模型可能给出语义上接近的对象，却没有足够证据说明二者真的相关。哨望先采用确定性规则，只有 ATLAS 与论文等弱关联才引入模型，并设置置信度与 Critic 门槛。

每条边的理由、置信度、方法和创建角色写入 Schema，缺失就不能作为合格输出。用户在图谱上看到的不是一个孤立的“相关”标签，而是可以检查原文字段或候选证据的解释。这个区别连接了 2.5.2 的规则、3.1.2 的图模型和 S-03 的界面要求。

可解释不等于正确，但错误至少有可定位的依据。第四章 4.3 将按合并、版本和 ATLAS 分类测量，并比较 Critic 前后结果及误拦率。当前尚无金标成绩，不把“边带理由”本身写成准确率已提高的证据。

5.3 从依赖文件出发的“我受不受影响”自查

一份高危清单仍要求开发者逐项对照自己的依赖。哨望把判断入口改为依赖文件和组件版本，按生态解析，再对 OSV 区间求解。用户得到的是与清单有关的结果和修复依据，减少从情报阅读到版本核对之间的手工转换。

结果明确区分受影响、未发现已知影响和组件未收录，来源冲突也保留。这个区分比给出一个简单的绿色“安全”提示更重要：覆盖不足需要补资料，已知区间未命中才是当前知识下的否定结果。2.5.4 的设计和 C-02 的参考实现围绕同一边界展开。

Web、MCP 与命令行共享求解能力，使同一判断可以进入分析师页面和 CI 门禁。它是否解析正确，靠 4.3 的版本金标；是否真正进入开发流程，靠 4.6 的客户端调用与 S-09 的退出码记录。两个证据缺一不可，不能用页面有按钮代替已集成。

5.4 可解释 GraphRAG 问答

普通检索问答容易把检索和生成压成一次不可见过程。用户即使拿到答案，也难以判断版本条件、时间范围和关系路径是否逐项满足。哨望把多跳问题拆成结构化子问题，记录检索方式和命中数，再用逐句引用与返回前校验约束生成。

BM25 处理编号与版本，向量处理语义，图扩展连接文本不相似但存在关系的证据。RRF 统一排名、重排控制候选数量；这套组合的目的不是多取材料，而是保住回答所需的中间证据。2.6 的流程与 3.2.3、3.2.4 的节选给出机制，S-04 要求展示实际推理路径。

引用校验把不存在的来源与不支持结论的来源分开处理，partial 显示残余不确定性。第四章 4.4 的三组对照将验证组合效果；在结果回填前，不声称图扩展一定提高准确率，也不把 Critic 判定当成人工正确答案。

5.5 内部多智能体编排与外部 MCP 开放统一

内部有智能体并不意味着外部开发工具就能使用情报。相反，如果内部依赖自由对话、外部又各写一套接口，很难解释一次答案来自哪次任务。哨望内部以有状态图组织九个角色，外部以统一服务层开放工具，两者共享事实和任务身份。

长任务句柄把这种联系带到客户端。预计超过六十秒时先返回 task_id，再通过固定续取工具读取；调用方不必维持一个脆弱的长连接，也不需要知道内部重试细节。六个只读工具和一个可选订阅把权限范围收紧，第三方扩展不能任意写入情报。

设计对应 2.3、2.7 与 C-06。官方配置文档已核对，真实客户端兼容性仍要按 4.6.1 测量。当前证据支持配置有来源，不支持“所有编码智能体已接通”，更不支持把未来 A2A 协作算作现有能力。

5.6 时效可观测与故障自愈

只报告“实时”无法解释用户为什么仍看到旧情报。哨望用五段时间戳把来源发布时间、首次发现、归一、富化和可查询连接起来，按来源公布分位数。六小时指标限定漏洞类首次发现，日更来源与 DEMO 分离，使时效数字具有明确对象。

可观测与恢复相连：来源级告警发现新鲜度异常，平台重试和死信处理短暂故障，备用通道维持部分覆盖，维度隔离避免一个慢接口拖住全部画像。降级和 stale 状态同时公开，保留缓存不被写成刚测成功。

机制见 2.2、3.1.3 和 3.1.4，证据将来自 4.2 的连续时延与 4.5 的故障注入。已有 CNVD、arXiv 失败记录说明预设备用路径有现实必要，却不等于自动切换与检查点恢复已经通过测试。

5.7 开放的插件生态

扩展接口若只规定“能调用”，没有数据和权限约束，第三方插件很容易形成新的事实格式或绕过审核。哨望把八类 Schema、三类扩展点和默认拒绝权限放在一起：插件提交材料与补丁，平台校验并统一写图。

标准映射降低交换障碍，版本规则说明消费者如何升级；签名索引、夹具回放和安全检查约束分发。没有原生字段的语义使用扩展保留，不能假定所有标准可直接表达全部信息。公开接口的价值在于边界可检查，而不是无限开放权限。

2.7.3 给出生命周期和贡献要求，第三章部署与合规部分说明运行边界。现阶段没有第三方插件规模或推荐通过率的实测，不能用生态设计推导已有社区成效。后续应先让一个符合约束的扩展完成回放、校验和运行记录，再讨论覆盖扩大。

第六章 总结与展望

本章回到作品提出的三个挑战：怎样更早发现分散材料，怎样在冲突与推断中保留证据，怎样回答具体组件问题并进入开发流程。设计已经给出相应机制，工程实测也改变了若干来源与计数策略；尚未测量的质量和性能继续保留缺口，不把方案完整度等同于运行完成度。

6.1 工作总结

哨望以监测、富化和问答为主线：九类来源按等级与频率发现材料，九维画像补全处置所需信息，六类关联连接公告、组件与研究证据；三路检索和版本自查把知识转成具体问题的回答。九个角色通过有状态图协作，对外以 MCP、OpenAPI、命令行和插件开放，事实源与权限边界保持统一。

第一点工程体会是，证据应比模型结论保存得更完整。评分主值需要落选值，关系边需要理由，问答需要支撑片段；来源撤回和版本分歧也要作为状态保留。否则一旦结果受到质疑，系统只能再次询问模型，无法解释此前为什么作出判断。

第二点体会是，时效只有拆开才容易改进。五段时间戳将来源发布、发现和内部处理分离，DEMO 与日更源又从六小时指标中剥离。这样，连续运行后才能定位瓶颈；一次接口成功或一次演示很快，都不能替代这套观测。

第三点体会是，开放要落实为可执行的限制。默认只读工具、插件无写图权、PoC 仅链接、暴露面仅计数，使服务可以被编码智能体调用，同时避免扩展获得任意执行或资产枚举能力。权限和 Schema 的约束比使用说明中的承诺更容易检查。

已有工程记录支持三项具体调整：CNVD 受限后改变国内来源主次，arXiv export API 失败后调整主通道，Quake 宽指纹经收窄与抽样后用于 Ollama 计数。它们证明了先验证接口与统计口径的必要性；端到端时延、富化准确率、问答质量和自愈能力仍待回填。

6.2 不足与展望

当前最直接的缺口是证据完整性。境内 2026-10-14 的原始输出未存档，需要复测补日志；CNNVD 数据接口、境内 arXiv RSS 和 Hunter 业务 API 仍需确认。截图、

客户端调用、连续运行与金标评测没有由本次材料提供完整实录，参考代码也需与最终仓库对齐。

弱关联和 Critic 都可能误判。后续应先完成二百条金标、约一百题问答及同条件对照，保留误合并、误拦和引用失配的错例，再决定模型、提示或规则怎样调整。只有一种模型或一批容易样本上的结果，不能代表系统面对所有新材料的表现。

暴露面目前只有 Ollama 的 Quake 校准，其他九个组件和 Hunter、FOFA 计数仍待测。国内 AI 推理栈周快照及覆盖提升对照属于后续计划；版本可识别率不足时仍不展示受影响数量。不同平台各自保留快照与口径，避免为了汇总而相加。

能力扩展保持明确顺序。独立 exposure_stats 工具、A2A Agent Card、Kubernetes 与 Helm 部署属于规划，不计入当前七工具和已有验证。先补齐运行证据，再依据实际容量和协作需求扩展，才能让下一阶段的设计决定建立在可复查的事实之上。

参考文献

[1] Wiz Research. Probllama: Ollama remote code execution vulnerability (CVE-2024-37032): overview and mitigations[EB/OL]. (2024-06-24)[2026-10-15]. https://www.wiz.io/blog/probllama-ollama-vulnerability-cve-2024-37032.

[2] Oligo Security. ShadowRay: first known attack campaign targeting AI workloads exploited in the wild[EB/OL]. (2024-03-26)[2026-10-15]. https://www.oligo.security/blog/shadowray-attack-ai-workloads-actively-exploited-in-the-wild.

[3] GitHub. GHSA-hj4w-hm2g-p6w5: vLLM vulnerable to remote code execution via Mooncake integration[EB/OL]. (2025-04-29)[2026-10-15]. https://github.com/advisories/GHSA-hj4w-hm2g-p6w5.

[4] National Institute of Standards and Technology. NVD news: program announcement[EB/OL]. (2024-04-25)[2026-10-15]. https://nvd.nist.gov/general/news.

[5] VulnCheck. The real danger lurking in the NVD backlog[EB/OL]. (2024-05-23)[2026-10-15]. https://www.vulncheck.com/blog/nvd-backlog-exploitation.

[6] VulnCheck. Danger is still lurking in the NVD backlog[EB/OL]. (2024-09-30)[2026-10-15]. https://www.vulncheck.com/blog/nvd-backlog-exploitation-lurking.

[7] LYONS J. NIST's security flaw database still backlogged with 17K+ unprocessed bugs. Not great[EB/OL]. The Register, (2024-10-02)[2026-10-15]. https://www.theregister.com/security/2024/10/02/nvd-still-backlogged-with-17k-unprocessed-bugs/675161.

[8] GAMBLIN J. 2024 CVE data review[EB/OL]. (2025-01-05)[2026-10-15]. https://www.jerrygamblin.com/2025/01/05/2024-cve-data-review/.

[9] OWASP Foundation. OWASP Top 10 for LLM applications 2025[EB/OL]. (2024-11-18)[2026-10-15]. https://genai.owasp.org/llm-top-10/.

[10] National Institute of Standards and Technology. Artificial intelligence risk management framework (AI RMF 1.0): NIST AI 100-1[R]. Gaithersburg: NIST, 2023. DOI: 10.6028/NIST.AI.100-1.

[11] National Institute of Standards and Technology. Artificial intelligence risk management framework: generative artificial intelligence profile: NIST AI 600-1[R]. Gaithersburg: NIST, 2024. DOI: 10.6028/NIST.AI.600-1.

[12] 国家互联网信息办公室, 国家发展和改革委员会, 教育部, 等. 生成式人工智能服务管理暂行办法 [EB/OL]. (2023-07-13)[2026-10-15]. https://www.cac.gov.cn/2023-07/13/c_1690898327029107.htm.

[13] 工业和信息化部, 国家互联网信息办公室, 公安部. 网络产品安全漏洞管理规定: 工信部联网安〔2021〕66 号[A/OL]. (2021-07-12)[2026-10-15]. https://www.gov.cn/zhengce/zhengceku/2021-07/14/content_5624965.htm.

[14] National Institute of Standards and Technology. NVD vulnerability APIs (CVE API 2.0)[EB/OL]. [2026-10-15]. https://nvd.nist.gov/developers/vulnerabilities.

[15] Open Source Security Foundation. Open Source Vulnerability (OSV) schema[EB/OL]. [2026-10-15]. https://ossf.github.io/osv-schema/.

[16] Cybersecurity and Infrastructure Security Agency. Known exploited vulnerabilities catalog[EB/OL]. [2026-10-15]. https://www.cisa.gov/known-exploited-vulnerabilities-catalog.

[17] JACOBS J, ROMANOSKY S, EDWARDS B, et al. Exploit prediction scoring system (EPSS)[J]. Digital Threats: Research and Practice, 2021, 2(3): 1-17.

[18] OASIS. STIX version 2.1[S]. OASIS Standard, 2021.

[19] OASIS. Common security advisory framework version 2.0[S]. OASIS Standard, 2022.

[20] WAGNER C, DULAUNOY A, WAGENER G, et al. MISP: the design and implementation of a collaborative threat intelligence sharing platform[C]//Proceedings of the 2016 ACM Workshop on Information Sharing and Collaborative Security. New York: ACM, 2016: 49-56.

[21] Filigran. OpenCTI: open cyber threat intelligence platform[CP/OL]. [2026-10-15]. https://github.com/OpenCTI-Platform/opencti.

[22] MITRE. Common weakness enumeration (CWE)[EB/OL]. [2026-10-15]. https://cwe.mitre.org/.

[23] MITRE. ATLAS: adversarial threat landscape for artificial-intelligence systems[EB/OL]. [2026-10-15]. https://atlas.mitre.org/.

[24] ALAM M T, BHUSAL D, NGUYEN L, et al. CTIBench: a benchmark for evaluating LLMs in cyber threat intelligence[C]//Advances in Neural Information Processing Systems 37: Datasets and Benchmarks Track. 2024.

[25] LIU X, LIANG J, YAN Q, et al. CyLens: towards reinventing cyber threat intelligence in the paradigm of agentic large language models[EB/OL]. arXiv: 2502.20791, 2025.

[26] PAUL S, ALEMI F, MACWAN R. LLM-assisted proactive threat intelligence for automated reasoning[EB/OL]. arXiv: 2504.00428, 2025.

[27] LEWIS P, PEREZ E, PIKTUS A, et al. Retrieval-augmented generation for knowledge-intensive NLP tasks[C]//Advances in Neural Information Processing Systems 33. 2020: 9459-9474.

[28] EDGE D, TRINH H, CHENG N, et al. From local to global: a graph RAG approach to query-focused summarization[EB/OL]. arXiv: 2404.16130, 2024.

[29] TRIVEDI H, BALASUBRAMANIAN N, KHOT T, et al. Interleaving retrieval with chain-of-thought reasoning for knowledge-intensive multi-step questions[C]//Proceedings of the 61st Annual Meeting of the Association for Computational Linguistics. Toronto: ACL, 2023: 10014-10037.

[30] GAO T, YEN H, YU J, et al. Enabling large language models to generate text with citations[C]//Proceedings of the 2023 Conference on Empirical Methods in Natural Language Processing. Singapore: ACL, 2023: 6465-6488.

[31] CORMACK G V, CLARKE C L A, BUETTCHER S. Reciprocal rank fusion outperforms condorcet and individual rank learning methods[C]//Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval. New York: ACM, 2009: 758-759.

[32] ES S, JAMES J, ESPINOSA-ANKE L, et al. RAGAs: automated evaluation of retrieval augmented generation[C]//Proceedings of the 18th Conference of the European Chapter of the Association for Computational Linguistics: System Demonstrations. St. Julians: ACL, 2024: 150-158.

[33] GRESHAKE K, ABDELNABI S, MISHRA S, et al. Not what you've signed up for: compromising real-world LLM-integrated applications with indirect prompt injection[C]//Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security. New York: ACM, 2023: 79-90.

[34] YAO S, ZHAO J, YU D, et al. ReAct: synergizing reasoning and acting in language models[C]//International Conference on Learning Representations. 2023.

[35] WU Q, BANSAL G, ZHANG J, et al. AutoGen: enabling next-gen LLM applications via multi-agent conversation[EB/OL]. arXiv: 2308.08155, 2023.

[36] LangChain. LangGraph documentation[EB/OL]. [2026-10-15]. https://langchain-ai.github.io/langgraph/.

[37] Model Context Protocol. Specification, version 2025-11-25[EB/OL]. (2025-11-25)[2026-10-15]. https://modelcontextprotocol.io/specification/2025-11-25.

[38] Linux Foundation. Agent2Agent (A2A) protocol specification[EB/OL]. [2026-10-15]. https://a2a-protocol.org/latest/specification/.

[39] CHEN J, XIAO S, ZHANG P, et al. BGE M3-embedding: multi-lingual, multi-functionality, multi-granularity text embeddings through self-knowledge distillation[EB/OL]. arXiv: 2402.03216, 2024.

[40] TZIAKOURIS G, BIASIOTTO E. Detecting exposed LLM servers: a Shodan case study on Ollama[EB/OL]. Cisco Blogs, (2025-09)[2026-10-15]. https://blogs.cisco.com/security/detecting-exposed-llm-servers-shodan-case-study-on-ollama.

附录 A 数据源连通性实测

这份记录要回答的是：在计划部署的网络环境里，哪些入口能够直接访问，哪些需要替代通道。2026-10-14 的境内检查已经给出响应结果，但原始终端输出没有存档；因此本附录以 dossier 记录为初稿，不补写请求耗时、命令输出或文件哈希。正文 3.1.6 和 4.6.2 引用同一事实边界。

当时 NVD、GitHub、OSV、CISA KEV、FIRST EPSS、huntr、MITRE ATLAS 均返回 200，CNNVD 首页与 TC260 也返回 200。这个结果使直连成为当时可采用的部署方案。另一方面，CNVD 三入口返回 521、arXiv export API 返回 502，说明“有公开网站”不足以保证连接器能长期取得数据，必须为不同失败保留处理路径。

表 A-1 境内入口实测初稿

来源或入口	类别	结果	日期与环境	处置
NVD / GitHub / OSV / KEV / EPSS / huntr / ATLAS	主要来源	HTTP 200	2026-10-14，境内	当时支持直连
CNNVD 首页；TC260	国内来源 / 标准	200	2026-10-14，境内	数据接口 / 标准文件待补
CNVD 三入口	国内来源	521	2026-10-14，境内	人工或半自动导入
arXiv export API	论文	502	2026-10-14，境内	RSS 主通道，境内待测
Quake 查询接口	测绘	调用成功	2026-10-14，境内	另做语法校准
Hunter 首页	测绘	200	2026-10-14，境内	业务 API 待测
FOFA	测绘	820031	2026-10-14，境内	积分不足
ZoomEye	测绘	鉴权未核实	2026-10-14，境内	暂不启用

CNVD 的处理是降为加分项并保留人工导入，不做验证绕过；CNNVD 成为国内主力候选，但具体数据接口仍待确认。arXiv 改以 RSS 为主，export API 补漏，其

他渠道备用。这里的方案调整发生在观测之后，不能倒写成失败入口已修复。Hunter 首页同样不能替代业务 API 测试，FOFA 的积分不足也不是网络不可达。

第二轮补充发生在 2026-10-15 15:57 的境外环境。arXiv RSS 为 200，Semantic Scholar bulk 为 429，avid-db 仓库为 200，Hunter 首页为 403。它们用于解释备用通道与环境差异，不覆盖第一轮境内结论；尤其不能用境外 RSS 成功删除境内 RSS 待测项。

表 A-2 境外补充观测与证据边界

入口	结果	采集环境与时间	证据状态
arXiv RSS	200	境外，2026-10-15 15:57	dossier 记录
Semantic Scholar bulk	429	境外，2026-10-15 15:57	无凭据限流记录
avid-db 仓库	200	境外，2026-10-15 15:57	dossier 记录
Hunter 首页	403	境外，2026-10-15 15:57	不能替代境内 API 结果
境内原始日志与哈希	【实录待补】	需境内复跑	原终端输出未存档

材料还记录了 2026-10-14 境外多个来源接口、仓库和页面返回 200，以及 AVID API 403、Protect AI 和 HiddenLayer RSS 404。不同入口属于不同能力：仓库可读不等于 API 可用，网页可打开不等于数据解析完整。复测时需要逐入口登记，而不能只在“平台可用”一栏打钩。

补证据应保留时间、网络环境、公开入口、状态码、结论和处置，并保存脱敏后的原始响应摘要。境内计划复跑 cn-network-test.sh；本次重写没有执行网络复测。记录文件、采集时刻与哈希前十二位为【实录待补】。若复测变化，应新增一行记录，保留旧结果，而不是改写历史响应。

附录 B 测绘平台查询记录

这一组记录检验的是查询语法能否代表指定组件，不是目标是否可被利用。当前只有 Ollama 的 Quake 查询已有计数与抽样结果，其他组件和平台仍待测。正文

2.5.1 用它说明暴露面约束，4.6.2 展开实测分析；这里保留按快照复核所需的时间和方法。

2026-10-14 首次使用宽应用指纹得到约八十二万条，次日 15:57 为 823 690。数量本身不能证明全是错误，但相对于另一平台文献中的规模，足以提示语法需要检查。于是增加端口 11434 与响应特征“Ollama is running”，把“某平台识别为相关应用”收窄为更具体的服务特征。

表 B-1 Quake 查询快照记录

时间（北京）	语法	结果	说明
2026-10-14	app:"Ollama"	约 82 万	首次实测，判定过宽
2026-10-15 15:57	app:"Ollama"（宽口径）	823 690	只作上限参考，不展示
2026-10-15 15:57	port:11434 AND response:"Ollama is running"（收窄）	172 411（约 17.2 万）	全球
2026-10-15 15:57	收窄 + country:"China"	51 612（约 5.2 万）	国内（以平台国家字段为准）
2026-10-15 19:55	收窄语法 50 条元数据抽样	44/50 命中，精确率 88%	≥80% 门槛，状态 verified（抽样时平台返回总数为 172 401）

15:57 的全球 172 411 与中国 51 612 是同一时点下不同条件的计数；19:55 的抽样则是后续校准，平台总数已为 172 401。两次相差十条只说明快照不同，本报告不推断资产上线、下线或平台更新原因。保留时间比选择一个数覆盖另一个更适合复查。

表 B-2 组件语法校准台账

组件	平台	校准结果	时间与证据
Ollama	Quake	44 / 50，88%，verified	2026-10-15 19:55；哈希待补
vLLM	待测平台	【实录待补】	未采集实录
Dify	待测平台	【实录待补】	未采集实录
ComfyUI	待测平台	【实录待补】	未采集实录
Gradio	待测平台	【实录待补】	未采集实录
Open WebUI	待测平台	【实录待补】	未采集实录

组件	平台	校准结果	时间与证据
NVIDIA Triton	待测平台	【实录待补】	未采集实录
Langflow	待测平台	【实录待补】	未采集实录
Flowise	待测平台	【实录待补】	未采集实录
Ray Dashboard	待测平台	【实录待补】	未采集实录

五十条元数据中四十四条符合条件，精确率 88%，达到规定的百分之八十门槛，所以该收窄语法可标 verified。这个标签针对语法校准，不能读成“已确认这些服务存在漏洞”。版本分布不充分时也不能推出受影响估计；整体版本可识别率低于 0.3 时，设计禁止展示该估计。

抽样过程只需要记录第几条是否符合判断标准，不保留地址、资产详情或响应原文。现有材料提供的是汇总计数，未提供五十条逐条判定表，因此不能在此补造四十四个“是”和六个“否”的排列。逐条脱敏判定、采集时刻与哈希前十二位为【实录待补】。

后续计划覆盖 vLLM、Dify、ComfyUI、Gradio、Open WebUI、NVIDIA Triton、Langflow、Flowise 和 Ray Dashboard。端口相同不足以区分组件，需结合标题或响应特征。每个组件独立校准，不能沿用 Ollama 的精确率；Hunter、FOFA 的计数也不能由 Quake 推得，ZoomEye 在鉴权核实前保持禁用。

材料列出的证据位置为 evidence/20261015/B-exposure/，包含 SHA256SUMS，并记有 evidence/_audit/scan-20261015.txt 的脱敏结果。本次附件不含这些原始文件，未进行重新哈希或扫描，故不能给出哈希前缀。正式归档应只追加新快照，并保留 provider、语法标识、测量时间和脱敏审计。

附录 C 端到端运行追踪

本附录要证明一条情报真正经过采集、归一、富化、校验、写入与查询，而不是各模块分别存在一个演示按钮。当前没有完整运行实录，所有执行内容为【实录待补】。正文 2.2 的流程、3.3 的任务树与第四章时效表应最终指向同一批可追踪记录。

追踪需要一条真实第三方样本和一条演示注入样本，分别保存。真实样本保留来源发布时间及精度、首次发现和可查询时间；演示样本显式带 DEMO，展示后续状态交接，但不进入真实时效分母。二者可以使用相同流程，却不能混成一条“秒级发现”的性能证据。

表 C-1 真实与演示样本阶段追踪模板

记录项	真实第三方样本	演示注入样本
身份与来源	【实录待补】	【实录待补】
source_published_at	【实录待补】	【实录待补】
first_seen_at	【实录待补】	【实录待补】
normalized_at	【实录待补】	【实录待补】
enriched_at	【实录待补】	【实录待补】
queryable_at	【实录待补】	【实录待补】
Critic / 冲突 / 关系证据	【实录待补】	【实录待补】
统计归属	漏洞类首次发现按协议计入	DEMO 排除

每次运行除阶段时间外，还应记录任务身份、来源外部编号、使用的文档版本和阶段状态。若富化中一个维度等待配额，要看到其他维度如何完成；若 Critic 驳回，应保留原输出、驳回理由与后续处理，不能只截最终成功节点。当前这些内容没有由材料提供，不据示意图补写日志。

冲突与关系也是追踪的一部分。样本应能从详情卡回到字段候选及裁决依据，再从图边理由回到相应证据；问答摘录则显示引用如何使用这些材料。它们回答的是“为什么这样判断”，不是单纯统计经过了几个智能体。

Langfuse trace 截图、任务树截图、冲突记录与问答摘录均为【实录待补】。后续若新增附录截图，从 AS-01 编号，并与真实采集时刻、文件名和哈希前十二位一起登记。截图应去除身份和秘密，不能为了证明调用真实而公开凭据或资产明细。

运行失败同样有价值。真实来源暂不可达时应登记失败和降级路径，不能换成演示材料后仍沿用真实标签；如果流程只完成到富化阶段，就保留部分完成状态。补证据后，正文的完成度也按实际结果更新，不能只删除占位而不核对条件。

附录 D 外部智能体调用实录

本附录区分配置依据与实际调用。2026-10-14 已核对 Claude Code、Codex、Cursor 官方 MCP 文档，尚未在演示机验证工具加载、只读策略和长任务续取。因此当前可确认的是接入方案有文档依据，真实调用记录为【实录待补】。

同一工具在不同客户端中可能采用不同配置形式。Claude Code 的 HTTP 条目、Codex 的 TOML 与 Cursor 的 URL 配置不能互相复制；Gemini 远程字段等项目仍待确认。实录应记录当时客户端和传输方式，不能只写一个客户端名称便宣称所有连接方式通过。

表 D-1 客户端调用实录登记模板

客户端与路径	工具加载	只读策略	长任务续取	记录文件
Claude Code	【实录待补】	【实录待补】	【实录待补】	【实录待补】
Codex 远程	【实录待补】	【实录待补】	【实录待补】	【实录待补】
Codex stdio	【实录待补】	【实录待补】	【实录待补】	【实录待补】
Cursor 远程	【实录待补】	【实录待补】	【实录待补】	【实录待补】
Gemini CLI stdio	【实录待补】	【实录待补】	【实录待补】	【实录待补】
CLI / CI	【实录待补】	【实录待补】	【实录待补】	【实录待补】

一次完整自查对话应包括用户问题、实际选择的 check_stack、结构化结果、随后取详情或问答的过程及引用。预计耗时超过六十秒时，还应看到任务句柄与 get_task_result 续取。若客户端误把句柄当作最终答案，应如实记录失败，而不是把单次提交成功写成兼容通过。

只读工具是否免确认，要连同当时客户端策略记录。七工具设计中只有订阅是可选写入，客户端可以有自己的审批设置；服务端只读权限与界面弹窗是两个检查点。记录既要验证不会写情报，也要解释实际审批行为，不能仅凭工具注解推断所有客户端相同。

命令行记录对应 S-09，需要保留 shaowang check 的命令、脱敏输出和退出码。非零退出码必须说明来自高危依赖命中还是调用失败，只有前者能支持风险门禁演示。对话截图、日志文件、采集时刻与哈希前十二位均为【实录待补】。

如果某个客户端暂时不支持所需传输，应明确写失败范围，保留可用的独立路径；不能改换另一客户端后继续填原行。完成后再同步第四章兼容性矩阵和第三章截图，避免报告中出现“矩阵通过、截图仍是占位”的矛盾。

附录 E 性能与延迟原始记录

性能结果需要从原始时间和配置复算。本附录尚无真实连续运行数据，硬件、数据规模、观测天数和延迟记录为【实录待补】。第四章规定的目标并不填在原始结果栏，避免把约束条件误作测量值。

计划环境采用单机 docker compose，包含模型网关、嵌入与重排服务，以及事实、图与全文存储。正式运行时要登记实际 CPU、内存、磁盘、软件和模型版本，记录数据规模与网络环境。配置不同的两次运行分别保存，不能把更小数据量下的延迟与更大数据量下的准确率拼成一组结果。

表 E-1 性能运行环境登记模板

项目	实际运行记录
CPU / 内存 / 磁盘	【实录待补】
系统与服务版本	【实录待补】
模型 / 嵌入 / 重排版本	【实录待补】
网络环境	【实录待补】
数据规模	【实录待补】
代码与配置版本	【实录待补】
开始结束时间 / 观测天数	【实录待补】

时延记录保存五段时间戳及来源时间精度，首次发现样本、日更样本与 DEMO 使用明确标签。只有漏洞类首次发现进入六小时端到端统计；采集分位数和合计端到端分位数不能混用。来源只精确到日时按零点计算，这种保守高估要随结果说明。

表 E-2 来源时延原始记录索引

来源	样本与时间精度	CSV / 复算脚本	结果与哈希
P0 厂商公告	【实录待补】	【实录待补】	【实录待补】
GHSA	【实录待补】	【实录待补】	【实录待补】
NVD	【实录待补】	【实录待补】	【实录待补】

来源	样本与时间精度	CSV / 复算脚本	结果与哈希
OSV	【实录待补】	【实录待补】	【实录待补】
huntr	【实录待补】	【实录待补】	【实录待补】
日更来源（单列）	【实录待补】	【实录待补】	【实录待补】
DEMO（排除）	【实录待补】	【实录待补】	【实录待补】

连续运行目标不少于七天，不足则写实际天数。失败、等待和降级也是运行条件的一部分，原始文件不能只保留成功或低延迟记录。若发布时间缺失或不可信，应登记原因并按冻结协议处理，不能使用 first_seen_at 替代后得到人为缩短的端到端时延。

复算脚本需与时延 CSV、样本范围及结果一起封存。箱线图 F-28 当前不绘制，因为没有分布数据；补齐后图、表与原始文件必须一致。文件名、采集区间、脚本版本及哈希前十二位为【实录待补】，本次没有运行性能测试，也没有生成替代性的随机曲线。

结果分析应逐来源阅读，再看总体。某一类来源长期降级，可能使整体覆盖不足；总体 P95 即使达到目标，也不能掩盖这个问题。附录保留原始记录的目的，是让评审能重新计算并检查范围，而不只是接受报告中的一个数字。

附录 F 故障与修复记录

已有的工程记录并不是每一次都成功。保留 CNVD、arXiv、测绘口径和鉴权失败，能够解释方案为什么发生调整。本附录将外部条件与软件故障分开：换通道或降低主次关系属于应对，不代表对方接口被修复；缩窄查询属于口径校准，不是对目标服务进行安全验证。

表 F-1 已有失败与方案调整记录

事件	已有观察	调整	仍缺什么
CNVD	三入口 521	降低主次，人工导入	境内原始日志
arXiv	境内 export 502	RSS 主通道	境内 RSS 实测
Quake	宽计数约 82 万	收窄后抽样 88%	原始证据附件与哈希
FOFA	820031	积分足够后启用	计数实测

事件	已有观察	调整	仍缺什么
Hunter	境外首页 403	等待境内 API 测试	业务接口证据
ZoomEye	鉴权未核实	暂不启用	官方鉴权核对

CNVD 在 2026-10-14 的列表、网站信息和 RSS 三入口均为 521，材料判断为反爬。应对是降为加分项，保留人工或半自动导入，CNNVD 成为主力候选。这个决定牺牲了 CNVD 的自动化及时性，但没有绕过验证，也没有把首页可达的 CNNVD 数据接口写成已经跑通。

arXiv export API 在境内返回 502，使论文主通道调整为 RSS。次日境外 RSS 200 只能支持境外入口可达；Semantic Scholar bulk 429 又提醒备用路径也有配额条件。当前境内 RSS 和整条自动降级链仍缺实录，需要补测，而不是在报告中消除失败状态。

Quake 的问题发生在接口成功之后。宽语法返回约八十二万，收窄到端口与响应后，2026-10-15 15:57 得到全球 172 411、中国 51 612；19:55 五十条抽样四十四条符合条件，精确率 88%。调整的结果是语法通过既定门槛，宽计数退为上限参考，不能据此宣称全部暴露面都准确。

FOFA 返回 820031 表示积分不足，需要资源条件满足后再启用；Hunter 境内首页 200、境外首页 403，但业务 API 待测；ZoomEye 的鉴权方式与文档不一致，核实前禁用。这三类状态分别对应费用、环境与接口契约，不能统一记成网络故障后使用同一重试策略。

材料还记录了十三条口径统一工作。报告采用统一编号、七工具、九角色、六类关联与限定的六小时时效范围；本次重写继续按 D20 裁决，不把旧文档的不同叫法折中成新枚举。具体变更依据和仓库版本仍需由实际开发记录补齐。

表 F-2 故障注入运行登记模板

场景	实际转移与恢复	数据完整性	日志 / 时间 / 哈希
429 限流	【实录待补】	【实录待补】	【实录待补】
连续 503	【实录待补】	【实录待补】	【实录待补】
三周期 5xx	【实录待补】	【实录待补】	【实录待补】
400 参数错误	【实录待补】	【实录待补】	【实录待补】

场景	实际转移与恢复	数据完整性	日志 / 时间 / 哈希
暴露面维度超时	【实录待补】	【实录待补】	【实录待补】
终止 workers	【实录待补】	【实录待补】	【实录待补】

六类故障注入尚未执行。真实运行时应分别保留注入条件、任务身份、观察到的状态转移、恢复时间和是否丢失数据；400 参数错误的正确行为是不重试并告警，不应与 503 恢复混为一类。死信、熔断、维度隔离和检查点的结果均为【实录待补】。

原始失败日志、修复或调整记录的文件名、采集时刻与哈希前十二位为【实录待补】。不能在缺少日志时补一个看似真实的命令或提交号；也不能把参考代码里的流程图当作故障注入成功证据。补齐后，第四章可靠性结果应逐项能回到这里。

附录 G 评测集与评测运行记录

本附录负责把准确率与具体数据和配置绑定。二百条金标、约一百题问答是当前评测规模设计，不代表已完成标注和运行。标注文件、双人分歧、仲裁、模型版本、运行结果及错误分析均为【实录待补】。

金标覆盖合并、版本与 ATLAS，困难样本包括无编号公告、双 CVE 别名、评分冲突和不规范版本。两位标注者独立判断，第三人裁决，Cohen's κ 目标不低于 0.8。记录应保留为什么有分歧，而不只是最后一个统一标签；否则无法判断未来模型错在知识、语义还是样本本身。

表 G-1 数据集标注登记模板

数据集或类别	设计内容	实际标注记录
合并 / 版本 / ATLAS	200 条金标，含困难样本	【实录待补】
双人标注与仲裁	κ 目标 ≥0.8	【实录待补】
问答四题型	约 100 题，含答案与证据	【实录待补】
数据集版本与哈希	冻结样本与修订记录	【实录待补】

问答题按单文档事实、跨文档检索、多跳与深度分析区分，参考答案同时配证据。三种配置使用相同模型和生成提示，对照改变检索与校验；运行时还要保存实

际提示和 Schema 版本，避免“同名模型”掩盖配置变化。引用正确、答案正确和覆盖充分分别判定。

表 G-2 评测运行与错例登记模板

记录项	向量 RAG	BM25＋向量	三路＋Critic
代码版本 / 模型版本	【实录待补】	【实录待补】	【实录待补】
配置 / 提示 / Schema	【实录待补】	【实录待补】	【实录待补】
数据集 / 结果文件	【实录待补】	【实录待补】	【实录待补】
运行时间 / 哈希	【实录待补】	【实录待补】	【实录待补】
错误样本与归因	【实录待补】	【实录待补】	【实录待补】

每次运行记录代码版本、模型版本、配置、数据集版本、结果文件和采集时刻。Critic 前后比较使用同批关联，并保存误拦样本；不能只报告通过者准确率。某个运行失败时保留异常和未完成数量，不用上一次成功结果填本次行，也不把失败题删除后重新计算分母。

错例分析应包含问题或样本身份、预期结论、实际结论、支撑材料、错误归因及后续处理。若真实标注错误被确认，先保留修订记录，再统一重跑对照；若只是模型不认同金标，不足以成为修改金标的理由。当前错例内容为【实录待补】，本附录没有编造成功或失败样本。

最终归档包括原始标注、评测脚本、运行结果和证据哈希，确保第四章数字能够重新计算。文件名、运行时刻与哈希前十二位均为【实录待补】。直到这些记录补齐，正文继续保留待测状态，七项创新只能据设计与有限工程实测讨论，不能升级为性能结论。